
This content is from the eCFR and is authoritative but unofficial.

Title 45 — Public Welfare

Subtitle A — Department of Health and Human Services

Subchapter C — Administrative Data Standards and Related Requirements

Part 164 Security and Privacy

Subpart A General Provisions

- § 164.102 Statutory basis.
- § 164.103 Definitions.
- § 164.104 Applicability.
- § 164.105 Organizational requirements.
- § 164.106 Relationship to other parts.

Subpart B [Reserved]

Subpart C Security Standards for the Protection of Electronic Protected Health Information

- § 164.302 Applicability.
- § 164.304 Definitions.
- § 164.306 Security standards: General rules.
- § 164.308 Administrative safeguards.
- § 164.310 Physical safeguards.
- § 164.312 Technical safeguards.
- § 164.314 Organizational requirements.
- § 164.316 Policies and procedures and documentation requirements.
- § 164.318 Compliance dates for the initial implementation of the security standards.

Appendix A to Subpart C of Part 164

Security Standards: Matrix

Subpart D Notification in the Case of Breach of Unsecured Protected Health Information

- § 164.400 Applicability.
- § 164.402 Definitions.
- § 164.404 Notification to individuals.
- § 164.406 Notification to the media.
- § 164.408 Notification to the Secretary.
- § 164.410 Notification by a business associate.
- § 164.412 Law enforcement delay.
- § 164.414 Administrative requirements and burden of proof.

Subpart E Privacy of Individually Identifiable Health Information

- § 164.500 Applicability.

- § 164.501 Definitions.
- § 164.502 Uses and disclosures of protected health information: General rules.
- § 164.504 Uses and disclosures: Organizational requirements.
- § 164.506 Uses and disclosures to carry out treatment, payment, or health care operations.
- § 164.508 Uses and disclosures for which an authorization is required.
- § 164.509 Uses and disclosures for which an attestation is required.
- § 164.510 Uses and disclosures requiring an opportunity for the individual to agree or to object.
- § 164.512 Uses and disclosures for which an authorization or opportunity to agree or object is not required.
- § 164.514 Other requirements relating to uses and disclosures of protected health information.
- § 164.520 Notice of privacy practices for protected health information.
- § 164.522 Rights to request privacy protection for protected health information.
- § 164.524 Access of individuals to protected health information.
- § 164.526 Amendment of protected health information.
- § 164.528 Accounting of disclosures of protected health information.
- § 164.530 Administrative requirements.
- § 164.532 Transition provisions.
- § 164.534 Compliance dates for initial implementation of the privacy standards.
- § 164.535 Severability.

PART 164—SECURITY AND PRIVACY

Authority: 42 U.S.C. 1302(a); 42 U.S.C. 1320d-1320d-9; sec. 264, Pub. L. 104-191, 110 Stat. 2033-2034 (42 U.S.C. 1320d-2(note)); and secs. 13400-13424, Pub. L. 111-5, 123 Stat. 258-279.

Source: 65 FR 82802, Dec. 28, 2000, unless otherwise noted.

Subpart A—General Provisions

§ 164.102 Statutory basis.

The provisions of this part are adopted pursuant to the Secretary's authority to prescribe standards, requirements, and implementation specifications under part C of title XI of the Act, section 264 of Public Law 104-191, and sections 13400-13424 of Public Law 111-5.

[78 FR 5692, Jan. 25, 2013]

§ 164.103 Definitions.

As used in this part, the following terms have the following meanings:

Common control exists if an entity has the power, directly or indirectly, significantly to influence or direct the actions or policies of another entity.

Common ownership exists if an entity or entities possess an ownership or equity interest of 5 percent or more in another entity.

Covered functions means those functions of a covered entity the performance of which makes the entity a health plan, health care provider, or health care clearinghouse.

Health care component means a component or combination of components of a hybrid entity designated by the hybrid entity in accordance with § 164.105(a)(2)(iii)(D).

Hybrid entity means a single legal entity:

- (1) That is a covered entity;
- (2) Whose business activities include both covered and non-covered functions; and
- (3) That designates health care components in accordance with paragraph § 164.105(a)(2)(iii)(D).

Law enforcement official means an officer or employee of any agency or authority of the United States, a State, a territory, a political subdivision of a State or territory, or an Indian tribe, who is empowered by law to:

- (1) Investigate or conduct an official inquiry into a potential violation of law; or
- (2) Prosecute or otherwise conduct a criminal, civil, or administrative proceeding arising from an alleged violation of law.

Plan sponsor is defined as defined at section 3(16)(B) of ERISA, 29 U.S.C. 1002(16)(B).

Required by law means a mandate contained in law that compels an entity to make a use or disclosure of protected health information and that is enforceable in a court of law. *Required by law* includes, but is not limited to, court orders and court-ordered warrants; subpoenas or summons issued by a court, grand jury, a governmental or tribal inspector general, or an administrative body authorized to require the production of information; a civil or an authorized investigative demand; Medicare conditions of participation with respect to health care providers participating in the program; and statutes or regulations that require the production of information, including statutes or regulations that require such information if payment is sought under a government program providing public benefits.

[68 FR 8374, Feb. 20, 2003, as amended at 74 FR 42767, Aug. 24, 2009; 78 FR 34266, June 7, 2013]

§ 164.104 Applicability.

- (a) Except as otherwise provided, the standards, requirements, and implementation specifications adopted under this part apply to the following entities:
 - (1) A health plan.
 - (2) A health care clearinghouse.
 - (3) A health care provider who transmits any health information in electronic form in connection with a transaction covered by this subchapter.
- (b) Where provided, the standards, requirements, and implementation specifications adopted under this part apply to a business associate.

[68 FR 8375, Feb. 20, 2003, as amended at 78 FR 5692, Jan. 25, 2013]

§ 164.105 Organizational requirements.

(a)

(1) **Standard: Health care component.** If a covered entity is a hybrid entity, the requirements of this part, other than the requirements of this section, §§ 164.314, and 164.504, apply only to the health care component(s) of the entity, as specified in this section.

(2) **Implementation specifications:**

(i) **Application of other provisions.** In applying a provision of this part, other than the requirements of this section, §§ 164.314, and 164.504, to a hybrid entity:

- (A) A reference in such provision to a “covered entity” refers to a health care component of the covered entity;
- (B) A reference in such provision to a “health plan,” “covered health care provider,” or “health care clearinghouse,” refers to a health care component of the covered entity if such health care component performs the functions of a health plan, health care provider, or health care clearinghouse, as applicable;
- (C) A reference in such provision to “protected health information” refers to protected health information that is created or received by or on behalf of the health care component of the covered entity; and
- (D) A reference in such provision to “electronic protected health information” refers to electronic protected health information that is created, received, maintained, or transmitted by or on behalf of the health care component of the covered entity.

(ii) **Safeguard requirements.** The covered entity that is a hybrid entity must ensure that a health care component of the entity complies with the applicable requirements of this part. In particular, and without limiting this requirement, such covered entity must ensure that:

- (A) Its health care component does not disclose protected health information to another component of the covered entity in circumstances in which subpart E of this part would prohibit such disclosure if the health care component and the other component were separate and distinct legal entities;
- (B) Its health care component protects electronic protected health information with respect to another component of the covered entity to the same extent that it would be required under subpart C of this part to protect such information if the health care component and the other component were separate and distinct legal entities;
- (C) If a person performs duties for both the health care component in the capacity of a member of the workforce of such component and for another component of the entity in the same capacity with respect to that component, such workforce member must not use or disclose protected health information created or received in the course of or incident to the member's work for the health care component in a way prohibited by subpart E of this part.

(iii) **Responsibilities of the covered entity.** A covered entity that is a hybrid entity has the following responsibilities:

- (A) For purposes of subpart C of part 160 of this subchapter, pertaining to compliance and enforcement, the covered entity has the responsibility of complying with this part.
- (B) The covered entity is responsible for complying with §§ 164.316(a) and 164.530(i), pertaining to the implementation of policies and procedures to ensure compliance with applicable requirements of this part, including the safeguard requirements in paragraph (a)(2)(ii) of this section.
- (C) The covered entity is responsible for complying with §§ 164.314 and 164.504 regarding business associate arrangements and other organizational requirements.
- (D) The covered entity is responsible for designating the components that are part of one or more health care components of the covered entity and documenting the designation in accordance with paragraph (c) of this section, provided that, if the covered entity designates one or more health care components, it must include any component that would meet the definition of a covered entity or business associate if it were a separate legal entity. Health care component(s) also may include a component only to the extent that it performs covered functions.

(b)

- (1) **Standard: Affiliated covered entities.** Legally separate covered entities that are affiliated may designate themselves as a single covered entity for purposes of this part.
- (2) **Implementation specifications —**
 - (i) **Requirements for designation of an affiliated covered entity.**
 - (A) Legally separate covered entities may designate themselves (including any health care component of such covered entity) as a single affiliated covered entity, for purposes of this part, if all of the covered entities designated are under common ownership or control.
 - (B) The designation of an affiliated covered entity must be documented and the documentation maintained as required by paragraph (c) of this section.
 - (ii) **Safeguard requirements.** An affiliated covered entity must ensure that it complies with the applicable requirements of this part, including, if the affiliated covered entity combines the functions of a health plan, health care provider, or health care clearinghouse, §§ 164.308(a)(4)(ii)(A) and 164.504(g), as applicable.

(c)

- (1) **Standard: Documentation.** A covered entity must maintain a written or electronic record of a designation as required by paragraphs (a) or (b) of this section.
- (2) **Implementation specification: Retention period.** A covered entity must retain the documentation as required by paragraph (c)(1) of this section for 6 years from the date of its creation or the date when it last was in effect, whichever is later.

[68 FR 8375, Feb. 20, 2003, as amended at 78 FR 5692, Jan. 25, 2013]

§ 164.106 Relationship to other parts.

In complying with the requirements of this part, covered entities and, where provided, business associates, are required to comply with the applicable provisions of parts 160 and 162 of this subchapter.

[78 FR 5693, Jan. 25, 2013]

Subpart B [Reserved]

Subpart C—Security Standards for the Protection of Electronic Protected Health Information

Authority: 42 U.S.C. 1320d-2 and 1320d-4; sec. 13401, Pub. L. 111-5, 123 Stat. 260.

Source: 68 FR 8376, Feb. 20, 2003, unless otherwise noted.

§ 164.302 Applicability.

A covered entity or business associate must comply with the applicable standards, implementation specifications, and requirements of this subpart with respect to electronic protected health information of a covered entity.

[78 FR 5693, Jan. 25, 2013]

§ 164.304 Definitions.

As used in this subpart, the following terms have the following meanings:

Access means the ability or the means necessary to read, write, modify, or communicate data/information or otherwise use any system resource. (This definition applies to “access” as used in this subpart, not as used in subparts D or E of this part.)

Administrative safeguards are administrative actions, and policies and procedures, to manage the selection, development, implementation, and maintenance of security measures to protect electronic protected health information and to manage the conduct of the covered entity's or business associate's workforce in relation to the protection of that information.

Authentication means the corroboration that a person is the one claimed.

Availability means the property that data or information is accessible and useable upon demand by an authorized person.

Confidentiality means the property that data or information is not made available or disclosed to unauthorized persons or processes.

Encryption means the use of an algorithmic process to transform data into a form in which there is a low probability of assigning meaning without use of a confidential process or key.

Facility means the physical premises and the interior and exterior of a building(s).

Information system means an interconnected set of information resources under the same direct management control that shares common functionality. A system normally includes hardware, software, information, data, applications, communications, and people.

Integrity means the property that data or information have not been altered or destroyed in an unauthorized manner.

Malicious software means software, for example, a virus, designed to damage or disrupt a system.

Password means confidential authentication information composed of a string of characters.

Physical safeguards are physical measures, policies, and procedures to protect a covered entity's or business associate's electronic information systems and related buildings and equipment, from natural and environmental hazards, and unauthorized intrusion.

Security or Security measures encompass all of the administrative, physical, and technical safeguards in an information system.

Security incident means the attempted or successful unauthorized access, use, disclosure, modification, or destruction of information or interference with system operations in an information system.

Technical safeguards means the technology and the policy and procedures for its use that protect electronic protected health information and control access to it.

User means a person or entity with authorized access.

Workstation means an electronic computing device, for example, a laptop or desktop computer, or any other device that performs similar functions, and electronic media stored in its immediate environment.

[68 FR 8376, Feb. 20, 2003, as amended at 74 FR 42767, Aug. 24, 2009; 78 FR 5693, Jan. 25, 2013]

§ 164.306 Security standards: General rules.

(a) **General requirements.** Covered entities and business associates must do the following:

- (1) Ensure the confidentiality, integrity, and availability of all electronic protected health information the covered entity or business associate creates, receives, maintains, or transmits.
- (2) Protect against any reasonably anticipated threats or hazards to the security or integrity of such information.
- (3) Protect against any reasonably anticipated uses or disclosures of such information that are not permitted or required under subpart E of this part.
- (4) Ensure compliance with this subpart by its workforce.

(b) **Flexibility of approach.**

- (1) Covered entities and business associates may use any security measures that allow the covered entity or business associate to reasonably and appropriately implement the standards and implementation specifications as specified in this subpart.
- (2) In deciding which security measures to use, a covered entity or business associate must take into account the following factors:
 - (i) The size, complexity, and capabilities of the covered entity or business associate.
 - (ii) The covered entity's or the business associate's technical infrastructure, hardware, and software security capabilities.
 - (iii) The costs of security measures.

- (iv) The probability and criticality of potential risks to electronic protected health information.
- (c) **Standards.** A covered entity or business associate must comply with the applicable standards as provided in this section and in §§ 164.308, 164.310, 164.312, 164.314 and 164.316 with respect to all electronic protected health information.
- (d) **Implementation specifications.** In this subpart:
 - (1) Implementation specifications are required or addressable. If an implementation specification is required, the word “Required” appears in parentheses after the title of the implementation specification. If an implementation specification is addressable, the word “Addressable” appears in parentheses after the title of the implementation specification.
 - (2) When a standard adopted in § 164.308, § 164.310, § 164.312, § 164.314, or § 164.316 includes required implementation specifications, a covered entity or business associate must implement the implementation specifications.
 - (3) When a standard adopted in § 164.308, § 164.310, § 164.312, § 164.314, or § 164.316 includes addressable implementation specifications, a covered entity or business associate must—
 - (i) Assess whether each implementation specification is a reasonable and appropriate safeguard in its environment, when analyzed with reference to the likely contribution to protecting electronic protected health information; and
 - (ii) As applicable to the covered entity or business associate—
 - (A) Implement the implementation specification if reasonable and appropriate; or
 - (B) If implementing the implementation specification is not reasonable and appropriate—
 - §(1) Document why it would not be reasonable and appropriate to implement the implementation specification; and
 - §(2) Implement an equivalent alternative measure if reasonable and appropriate.
 - (e) **Maintenance.** A covered entity or business associate must review and modify the security measures implemented under this subpart as needed to continue provision of reasonable and appropriate protection of electronic protected health information, and update documentation of such security measures in accordance with § 164.316(b)(2)(iii).

[68 FR 8376, Feb. 20, 2003; 68 FR 17153, Apr. 8, 2003; 78 FR 5693, Jan. 25, 2013]

§ 164.308 Administrative safeguards.

- (a) A covered entity or business associate must, in accordance with § 164.306:
 - (1)
 - (i) **Standard: Security management process.** Implement policies and procedures to prevent, detect, contain, and correct security violations.
 - (ii) **Implementation specifications:**
 - (A) **Risk analysis (Required).** Conduct an accurate and thorough assessment of the potential risks and vulnerabilities to the confidentiality, integrity, and availability of electronic protected health information held by the covered entity or business associate.

- (B) **Risk management (Required).** Implement security measures sufficient to reduce risks and vulnerabilities to a reasonable and appropriate level to comply with § 164.306(a).
 - (C) **Sanction policy (Required).** Apply appropriate sanctions against workforce members who fail to comply with the security policies and procedures of the covered entity or business associate.
 - (D) **Information system activity review (Required).** Implement procedures to regularly review records of information system activity, such as audit logs, access reports, and security incident tracking reports.
- (2) **Standard: Assigned security responsibility.** Identify the security official who is responsible for the development and implementation of the policies and procedures required by this subpart for the covered entity or business associate.
- (3)
 - (i) **Standard: Workforce security.** Implement policies and procedures to ensure that all members of its workforce have appropriate access to electronic protected health information, as provided under paragraph (a)(4) of this section, and to prevent those workforce members who do not have access under paragraph (a)(4) of this section from obtaining access to electronic protected health information.
 - (ii) **Implementation specifications:**
 - (A) **Authorization and/or supervision (Addressable).** Implement procedures for the authorization and/or supervision of workforce members who work with electronic protected health information or in locations where it might be accessed.
 - (B) **Workforce clearance procedure (Addressable).** Implement procedures to determine that the access of a workforce member to electronic protected health information is appropriate.
 - (C) **Termination procedures (Addressable).** Implement procedures for terminating access to electronic protected health information when the employment of, or other arrangement with, a workforce member ends or as required by determinations made as specified in paragraph (a)(3)(ii)(B) of this section.
- (4)
 - (i) **Standard: Information access management.** Implement policies and procedures for authorizing access to electronic protected health information that are consistent with the applicable requirements of subpart E of this part.
 - (ii) **Implementation specifications:**
 - (A) **Isolating health care clearinghouse functions (Required).** If a health care clearinghouse is part of a larger organization, the clearinghouse must implement policies and procedures that protect the electronic protected health information of the clearinghouse from unauthorized access by the larger organization.
 - (B) **Access authorization (Addressable).** Implement policies and procedures for granting access to electronic protected health information, for example, through access to a workstation, transaction, program, process, or other mechanism.

- (C) **Access establishment and modification (Addressable).** Implement policies and procedures that, based upon the covered entity's or the business associate's access authorization policies, establish, document, review, and modify a user's right of access to a workstation, transaction, program, or process.

(5)

- (i) **Standard: Security awareness and training.** Implement a security awareness and training program for all members of its workforce (including management).
- (ii) **Implementation specifications.** Implement:
 - (A) **Security reminders (Addressable).** Periodic security updates.
 - (B) **Protection from malicious software (Addressable).** Procedures for guarding against, detecting, and reporting malicious software.
 - (C) **Log-in monitoring (Addressable).** Procedures for monitoring log-in attempts and reporting discrepancies.
 - (D) **Password management (Addressable).** Procedures for creating, changing, and safeguarding passwords.

(6)

- (i) **Standard: Security incident procedures.** Implement policies and procedures to address security incidents.
- (ii) **Implementation specification: Response and reporting (Required).** Identify and respond to suspected or known security incidents; mitigate, to the extent practicable, harmful effects of security incidents that are known to the covered entity or business associate; and document security incidents and their outcomes.

(7)

- (i) **Standard: Contingency plan.** Establish (and implement as needed) policies and procedures for responding to an emergency or other occurrence (for example, fire, vandalism, system failure, and natural disaster) that damages systems that contain electronic protected health information.
- (ii) **Implementation specifications:**
 - (A) **Data backup plan (Required).** Establish and implement procedures to create and maintain retrievable exact copies of electronic protected health information.
 - (B) **Disaster recovery plan (Required).** Establish (and implement as needed) procedures to restore any loss of data.
 - (C) **Emergency mode operation plan (Required).** Establish (and implement as needed) procedures to enable continuation of critical business processes for protection of the security of electronic protected health information while operating in emergency mode.
 - (D) **Testing and revision procedures (Addressable).** Implement procedures for periodic testing and revision of contingency plans.

(E) **Applications and data criticality analysis (Addressable).** Assess the relative criticality of specific applications and data in support of other contingency plan components.

(8) **Standard: Evaluation.** Perform a periodic technical and nontechnical evaluation, based initially upon the standards implemented under this rule and, subsequently, in response to environmental or operational changes affecting the security of electronic protected health information, that establishes the extent to which a covered entity's or business associate's security policies and procedures meet the requirements of this subpart.

(b)

(1) **Business associate contracts and other arrangements.** A covered entity may permit a business associate to create, receive, maintain, or transmit electronic protected health information on the covered entity's behalf only if the covered entity obtains satisfactory assurances, in accordance with § 164.314(a), that the business associate will appropriately safeguard the information. A covered entity is not required to obtain such satisfactory assurances from a business associate that is a subcontractor.

(2) A business associate may permit a business associate that is a subcontractor to create, receive, maintain, or transmit electronic protected health information on its behalf only if the business associate obtains satisfactory assurances, in accordance with § 164.314(a), that the subcontractor will appropriately safeguard the information.

(3) **Implementation specifications: Written contract or other arrangement (Required).** Document the satisfactory assurances required by paragraph (b)(1) or (b)(2) of this section through a written contract or other arrangement with the business associate that meets the applicable requirements of § 164.314(a).

[68 FR 8376, Feb. 20, 2003, as amended at 78 FR 5694, Jan. 25, 2013]

§ 164.310 Physical safeguards.

A covered entity or business associate must, in accordance with § 164.306:

(a)

(1) **Standard: Facility access controls.** Implement policies and procedures to limit physical access to its electronic information systems and the facility or facilities in which they are housed, while ensuring that properly authorized access is allowed.

(2) **Implementation specifications:**

(i) **Contingency operations (Addressable).** Establish (and implement as needed) procedures that allow facility access in support of restoration of lost data under the disaster recovery plan and emergency mode operations plan in the event of an emergency.

(ii) **Facility security plan (Addressable).** Implement policies and procedures to safeguard the facility and the equipment therein from unauthorized physical access, tampering, and theft.

(iii) **Access control and validation procedures (Addressable).** Implement procedures to control and validate a person's access to facilities based on their role or function, including visitor control, and control of access to software programs for testing and revision.

- (iv) **Maintenance records (Addressable).** Implement policies and procedures to document repairs and modifications to the physical components of a facility which are related to security (for example, hardware, walls, doors, and locks).
- (b) **Standard: Workstation use.** Implement policies and procedures that specify the proper functions to be performed, the manner in which those functions are to be performed, and the physical attributes of the surroundings of a specific workstation or class of workstation that can access electronic protected health information.
- (c) **Standard: Workstation security.** Implement physical safeguards for all workstations that access electronic protected health information, to restrict access to authorized users.
- (d)
 - (1) **Standard: Device and media controls.** Implement policies and procedures that govern the receipt and removal of hardware and electronic media that contain electronic protected health information into and out of a facility, and the movement of these items within the facility.
 - (2) **Implementation specifications:**
 - (i) **Disposal (Required).** Implement policies and procedures to address the final disposition of electronic protected health information, and/or the hardware or electronic media on which it is stored.
 - (ii) **Media re-use (Required).** Implement procedures for removal of electronic protected health information from electronic media before the media are made available for re-use.
 - (iii) **Accountability (Addressable).** Maintain a record of the movements of hardware and electronic media and any person responsible therefore.
 - (iv) **Data backup and storage (Addressable).** Create a retrievable, exact copy of electronic protected health information, when needed, before movement of equipment.

[68 FR 8376, Feb. 20, 2003, as amended at 78 FR 5694, Jan. 25, 2013]

§ 164.312 Technical safeguards.

A covered entity or business associate must, in accordance with § 164.306:

- (a)
 - (1) **Standard: Access control.** Implement technical policies and procedures for electronic information systems that maintain electronic protected health information to allow access only to those persons or software programs that have been granted access rights as specified in § 164.308(a)(4).
 - (2) **Implementation specifications:**
 - (i) **Unique user identification (Required).** Assign a unique name and/or number for identifying and tracking user identity.
 - (ii) **Emergency access procedure (Required).** Establish (and implement as needed) procedures for obtaining necessary electronic protected health information during an emergency.
 - (iii) **Automatic logoff (Addressable).** Implement electronic procedures that terminate an electronic session after a predetermined time of inactivity.

(iv) **Encryption and decryption (Addressable).** Implement a mechanism to encrypt and decrypt electronic protected health information.

(b) **Standard: Audit controls.** Implement hardware, software, and/or procedural mechanisms that record and examine activity in information systems that contain or use electronic protected health information.

(c)

(1) **Standard: Integrity.** Implement policies and procedures to protect electronic protected health information from improper alteration or destruction.

(2) **Implementation specification: Mechanism to authenticate electronic protected health information (Addressable).** Implement electronic mechanisms to corroborate that electronic protected health information has not been altered or destroyed in an unauthorized manner.

(d) **Standard: Person or entity authentication.** Implement procedures to verify that a person or entity seeking access to electronic protected health information is the one claimed.

(e)

(1) **Standard: Transmission security.** Implement technical security measures to guard against unauthorized access to electronic protected health information that is being transmitted over an electronic communications network.

(2) **Implementation specifications:**

(i) **Integrity controls (Addressable).** Implement security measures to ensure that electronically transmitted electronic protected health information is not improperly modified without detection until disposed of.

(ii) **Encryption (Addressable).** Implement a mechanism to encrypt electronic protected health information whenever deemed appropriate.

[68 FR 8376, Feb. 20, 2003, as amended at 78 FR 5694, Jan. 25, 2013]

§ 164.314 Organizational requirements.

(a)

(1) **Standard: Business associate contracts or other arrangements.** The contract or other arrangement required by § 164.308(b)(3) must meet the requirements of paragraph (a)(2)(i), (a)(2)(ii), or (a)(2)(iii) of this section, as applicable.

(2) **Implementation specifications (Required) –**

(i) **Business associate contracts.** The contract must provide that the business associate will—

(A) Comply with the applicable requirements of this subpart;

(B) In accordance with § 164.308(b)(2), ensure that any subcontractors that create, receive, maintain, or transmit electronic protected health information on behalf of the business associate agree to comply with the applicable requirements of this subpart by entering into a contract or other arrangement that complies with this section; and

(C) Report to the covered entity any security incident of which it becomes aware, including breaches of unsecured protected health information as required by § 164.410.

- (ii) **Other arrangements.** The covered entity is in compliance with paragraph (a)(1) of this section if it has another arrangement in place that meets the requirements of § 164.504(e)(3).
- (iii) **Business associate contracts with subcontractors.** The requirements of paragraphs (a)(2)(i) and (a)(2)(ii) of this section apply to the contract or other arrangement between a business associate and a subcontractor required by § 164.308(b)(4) in the same manner as such requirements apply to contracts or other arrangements between a covered entity and business associate.

(b)

- (1) **Standard: Requirements for group health plans.** Except when the only electronic protected health information disclosed to a plan sponsor is disclosed pursuant to § 164.504(f)(1)(ii) or (iii), or as authorized under § 164.508, a group health plan must ensure that its plan documents provide that the plan sponsor will reasonably and appropriately safeguard electronic protected health information created, received, maintained, or transmitted to or by the plan sponsor on behalf of the group health plan.
- (2) **Implementation specifications (Required).** The plan documents of the group health plan must be amended to incorporate provisions to require the plan sponsor to—
 - (i) Implement administrative, physical, and technical safeguards that reasonably and appropriately protect the confidentiality, integrity, and availability of the electronic protected health information that it creates, receives, maintains, or transmits on behalf of the group health plan;
 - (ii) Ensure that the adequate separation required by § 164.504(f)(2)(iii) is supported by reasonable and appropriate security measures;
 - (iii) Ensure that any agent to whom it provides this information agrees to implement reasonable and appropriate security measures to protect the information; and
 - (iv) Report to the group health plan any security incident of which it becomes aware.

[68 FR 8376, Feb. 20, 2003, as amended at 78 FR 5694, Jan. 25, 2013; 78 FR 34266, June 7, 2013]

§ 164.316 Policies and procedures and documentation requirements.

A covered entity or business associate must, in accordance with § 164.306:

- (a) **Standard: Policies and procedures.** Implement reasonable and appropriate policies and procedures to comply with the standards, implementation specifications, or other requirements of this subpart, taking into account those factors specified in § 164.306(b)(2)(i), (ii), (iii), and (iv). This standard is not to be construed to permit or excuse an action that violates any other standard, implementation specification, or other requirements of this subpart. A covered entity or business associate may change its policies and procedures at any time, provided that the changes are documented and are implemented in accordance with this subpart.

(b)

- (1) **Standard: Documentation.**
 - (i) Maintain the policies and procedures implemented to comply with this subpart in written (which may be electronic) form; and

- (ii) If an action, activity or assessment is required by this subpart to be documented, maintain a written (which may be electronic) record of the action, activity, or assessment.

(2) **Implementation specifications:**

- (i) **Time limit (Required).** Retain the documentation required by paragraph (b)(1) of this section for 6 years from the date of its creation or the date when it last was in effect, whichever is later.
- (ii) **Availability (Required).** Make documentation available to those persons responsible for implementing the procedures to which the documentation pertains.
- (iii) **Updates (Required).** Review documentation periodically, and update as needed, in response to environmental or operational changes affecting the security of the electronic protected health information.

[68 FR 8376, Feb. 20, 2003, as amended at 78 FR 5695, Jan. 25, 2013]

§ 164.318 Compliance dates for the initial implementation of the security standards.

(a) **Health plan.**

- (1) A health plan that is not a small health plan must comply with the applicable requirements of this subpart no later than April 20, 2005.
- (2) A small health plan must comply with the applicable requirements of this subpart no later than April 20, 2006.

(b) **Health care clearinghouse.** A health care clearinghouse must comply with the applicable requirements of this subpart no later than April 20, 2005.

(c) **Health care provider.** A covered health care provider must comply with the applicable requirements of this subpart no later than April 20, 2005.

Appendix A to Subpart C of Part 164—Security Standards: Matrix

Standards	Sections	Implementation Specifications (R) = Required, (A) = Addressable
ADMINISTRATIVE SAFEGUARDS		
Security Management Process	164.308(a)(1)	Risk Analysis (R) Risk Management (R) Sanction Policy (R) Information System Activity Review (R)
Assigned Security Responsibility	164.308(a)(2)	(R)
Workforce Security	164.308(a)(3)	Authorization and/or Supervision (A) Workforce Clearance Procedure Termination Procedures (A)
Information Access Management	164.308(a)(4)	Isolating Health care Clearinghouse Function (R)

Standards	Sections	Implementation Specifications (R) = Required, (A) = Addressable
Security Awareness and Training	164.308(a)(5)	Access Authorization (A) Access Establishment and Modification (A) Security Reminders (A) Protection from Malicious Software (A) Log-in Monitoring (A) Password Management (A)
Security Incident Procedures	164.308(a)(6)	Response and Reporting (R)
Contingency Plan	164.308(a)(7)	Data Backup Plan (R) Disaster Recovery Plan (R) Emergency Mode Operation Plan (R) Testing and Revision Procedure (A) Applications and Data Criticality Analysis (A)
Evaluation	164.308(a)(8)	(R)
Business Associate Contracts and Other Arrangement	164.308(b)(1)	Written Contract or Other Arrangement (R)
PHYSICAL SAFEGUARDS		
Facility Access Controls	164.310(a)(1)	Contingency Operations (A) Facility Security Plan (A) Access Control and Validation Procedures (A) Maintenance Records (A)
Workstation Use	164.310(b)	(R)
Workstation Security	164.310(c)	(R)
Device and Media Controls	164.310(d)(1)	Disposal (R) Media Re-use (R) Accountability (A) Data Backup and Storage (A)
TECHNICAL SAFEGUARDS (see § 164.312)		
Access Control	164.312(a)(1)	Unique User Identification (R) Emergency Access Procedure (R) Automatic Logoff (A) Encryption and Decryption (A)
Audit Controls	164.312(b)	(R)
Integrity	164.312(c)(1)	Mechanism to Authenticate Electronic Protected Health Information (A)
Person or Entity Authentication	164.312(d)	(R)
Transmission Security	164.312(e)(1)	Integrity Controls (A) Encryption (A)

Subpart D—Notification in the Case of Breach of Unsecured Protected Health Information

Source: 74 FR 42767, Aug. 24, 2009, unless otherwise noted.

§ 164.400 Applicability.

The requirements of this subpart shall apply with respect to breaches of protected health information occurring on or after September 23, 2009.

§ 164.402 Definitions.

As used in this subpart, the following terms have the following meanings:

Breach means the acquisition, access, use, or disclosure of protected health information in a manner not permitted under subpart E of this part which compromises the security or privacy of the protected health information.

(1) Breach excludes:

- (i) Any unintentional acquisition, access, or use of protected health information by a workforce member or person acting under the authority of a covered entity or a business associate, if such acquisition, access, or use was made in good faith and within the scope of authority and does not result in further use or disclosure in a manner not permitted under subpart E of this part.
- (ii) Any inadvertent disclosure by a person who is authorized to access protected health information at a covered entity or business associate to another person authorized to access protected health information at the same covered entity or business associate, or organized health care arrangement in which the covered entity participates, and the information received as a result of such disclosure is not further used or disclosed in a manner not permitted under subpart E of this part.
- (iii) A disclosure of protected health information where a covered entity or business associate has a good faith belief that an unauthorized person to whom the disclosure was made would not reasonably have been able to retain such information.

(2) Except as provided in paragraph (1) of this definition, an acquisition, access, use, or disclosure of protected health information in a manner not permitted under subpart E is presumed to be a breach unless the covered entity or business associate, as applicable, demonstrates that there is a low probability that the protected health information has been compromised based on a risk assessment of at least the following factors:

- (i) The nature and extent of the protected health information involved, including the types of identifiers and the likelihood of re-identification;
- (ii) The unauthorized person who used the protected health information or to whom the disclosure was made;
- (iii) Whether the protected health information was actually acquired or viewed; and
- (iv) The extent to which the risk to the protected health information has been mitigated.

Unsecured protected health information means protected health information that is not rendered unusable, unreadable, or indecipherable to unauthorized persons through the use of a technology or methodology specified by the Secretary in the guidance issued under section 13402(h)(2) of Public Law 111-5.

[78 FR 5695, Jan. 25, 2013]

§ 164.404 Notification to individuals.

(a) *Standard* —

- (1) **General rule.** A covered entity shall, following the discovery of a breach of unsecured protected health information, notify each individual whose unsecured protected health information has been, or is reasonably believed by the covered entity to have been, accessed, acquired, used, or disclosed as a result of such breach.
- (2) **Breaches treated as discovered.** For purposes of paragraph (a)(1) of this section, §§ 164.406(a), and 164.408(a), a breach shall be treated as discovered by a covered entity as of the first day on which such breach is known to the covered entity, or, by exercising reasonable diligence would have been known to the covered entity. A covered entity shall be deemed to have knowledge of a breach if such breach is known, or by exercising reasonable diligence would have been known, to any person, other than the person committing the breach, who is a workforce member or agent of the covered entity (determined in accordance with the federal common law of agency).

- (b) **Implementation specification: Timeliness of notification.** Except as provided in § 164.412, a covered entity shall provide the notification required by paragraph (a) of this section without unreasonable delay and in no case later than 60 calendar days after discovery of a breach.

(c) *Implementation specifications: Content of notification* —

- (1) **Elements.** The notification required by paragraph (a) of this section shall include, to the extent possible:
 - (A) A brief description of what happened, including the date of the breach and the date of the discovery of the breach, if known;
 - (B) A description of the types of unsecured protected health information that were involved in the breach (such as whether full name, social security number, date of birth, home address, account number, diagnosis, disability code, or other types of information were involved);
 - (C) Any steps individuals should take to protect themselves from potential harm resulting from the breach;
 - (D) A brief description of what the covered entity involved is doing to investigate the breach, to mitigate harm to individuals, and to protect against any further breaches; and
 - (E) Contact procedures for individuals to ask questions or learn additional information, which shall include a toll-free telephone number, an e-mail address, Web site, or postal address.
 - (2) **Plain language requirement.** The notification required by paragraph (a) of this section shall be written in plain language.
- (d) **Implementation specifications: Methods of individual notification.** The notification required by paragraph (a) of this section shall be provided in the following form:

- (1) **Written notice.** (i) Written notification by first-class mail to the individual at the last known address of the individual or, if the individual agrees to electronic notice and such agreement has not been withdrawn, by electronic mail. The notification may be provided in one or more mailings as information is available.
- (ii) If the covered entity knows the individual is deceased and has the address of the next of kin or personal representative of the individual (as specified under § 164.502(g)(4) of subpart E), written notification by first-class mail to either the next of kin or personal representative of the individual. The notification may be provided in one or more mailings as information is available.
- (2) **Substitute notice.** In the case in which there is insufficient or out-of-date contact information that precludes written notification to the individual under paragraph (d)(1)(i) of this section, a substitute form of notice reasonably calculated to reach the individual shall be provided. Substitute notice need not be provided in the case in which there is insufficient or out-of-date contact information that precludes written notification to the next of kin or personal representative of the individual under paragraph (d)(1)(ii).
- (i) In the case in which there is insufficient or out-of-date contact information for fewer than 10 individuals, then such substitute notice may be provided by an alternative form of written notice, telephone, or other means.
- (ii) In the case in which there is insufficient or out-of-date contact information for 10 or more individuals, then such substitute notice shall:
- (A) Be in the form of either a conspicuous posting for a period of 90 days on the home page of the Web site of the covered entity involved, or conspicuous notice in major print or broadcast media in geographic areas where the individuals affected by the breach likely reside; and
- (B) Include a toll-free phone number that remains active for at least 90 days where an individual can learn whether the individual's unsecured protected health information may be included in the breach.
- (3) **Additional notice in urgent situations.** In any case deemed by the covered entity to require urgency because of possible imminent misuse of unsecured protected health information, the covered entity may provide information to individuals by telephone or other means, as appropriate, in addition to notice provided under paragraph (d)(1) of this section.

§ 164.406 Notification to the media.

- (a) **Standard.** For a breach of unsecured protected health information involving more than 500 residents of a State or jurisdiction, a covered entity shall, following the discovery of the breach as provided in § 164.404(a)(2), notify prominent media outlets serving the State or jurisdiction.
- (b) **Implementation specification: Timeliness of notification.** Except as provided in § 164.412, a covered entity shall provide the notification required by paragraph (a) of this section without unreasonable delay and in no case later than 60 calendar days after discovery of a breach.
- (c) **Implementation specifications: Content of notification.** The notification required by paragraph (a) of this section shall meet the requirements of § 164.404(c).

[74 FR 42767, Aug. 24, 2009, as amended at 78 FR 5695, Jan. 25, 2013]

§ 164.408 Notification to the Secretary.

- (a) **Standard.** A covered entity shall, following the discovery of a breach of unsecured protected health information as provided in § 164.404(a)(2), notify the Secretary.
- (b) **Implementation specifications: Breaches involving 500 or more individuals.** For breaches of unsecured protected health information involving 500 or more individuals, a covered entity shall, except as provided in § 164.412, provide the notification required by paragraph (a) of this section contemporaneously with the notice required by § 164.404(a) and in the manner specified on the HHS Web site.
- (c) **Implementation specifications: Breaches involving less than 500 individuals.** For breaches of unsecured protected health information involving less than 500 individuals, a covered entity shall maintain a log or other documentation of such breaches and, not later than 60 days after the end of each calendar year, provide the notification required by paragraph (a) of this section for breaches discovered during the preceding calendar year, in the manner specified on the HHS web site.

[74 FR 42767, Aug. 24, 2009, as amended at 78 FR 5695, Jan. 25, 2013]

§ 164.410 Notification by a business associate.

- (a) **Standard –**
 - (1) **General rule.** A business associate shall, following the discovery of a breach of unsecured protected health information, notify the covered entity of such breach.
 - (2) **Breaches treated as discovered.** For purposes of paragraph (a)(1) of this section, a breach shall be treated as discovered by a business associate as of the first day on which such breach is known to the business associate or, by exercising reasonable diligence, would have been known to the business associate. A business associate shall be deemed to have knowledge of a breach if the breach is known, or by exercising reasonable diligence would have been known, to any person, other than the person committing the breach, who is an employee, officer, or other agent of the business associate (determined in accordance with the Federal common law of agency).
- (b) **Implementation specifications: Timeliness of notification.** Except as provided in § 164.412, a business associate shall provide the notification required by paragraph (a) of this section without unreasonable delay and in no case later than 60 calendar days after discovery of a breach.
- (c) **Implementation specifications: Content of notification.**
 - (1) The notification required by paragraph (a) of this section shall include, to the extent possible, the identification of each individual whose unsecured protected health information has been, or is reasonably believed by the business associate to have been, accessed, acquired, used, or disclosed during the breach.
 - (2) A business associate shall provide the covered entity with any other available information that the covered entity is required to include in notification to the individual under § 164.404(c) at the time of the notification required by paragraph (a) of this section or promptly thereafter as information becomes available.

[74 FR 42767, Aug. 24, 2009, as amended at 78 FR 5695, Jan. 25, 2013]

§ 164.412 Law enforcement delay.

If a law enforcement official states to a covered entity or business associate that a notification, notice, or posting required under this subpart would impede a criminal investigation or cause damage to national security, a covered entity or business associate shall:

- (a) If the statement is in writing and specifies the time for which a delay is required, delay such notification, notice, or posting for the time period specified by the official; or
- (b) If the statement is made orally, document the statement, including the identity of the official making the statement, and delay the notification, notice, or posting temporarily and no longer than 30 days from the date of the oral statement, unless a written statement as described in paragraph (a) of this section is submitted during that time.

§ 164.414 Administrative requirements and burden of proof.

- (a) **Administrative requirements.** A covered entity is required to comply with the administrative requirements of § 164.530(b), (d), (e), (g), (h), (i), and (j) with respect to the requirements of this subpart.
- (b) **Burden of proof.** In the event of a use or disclosure in violation of subpart E, the covered entity or business associate, as applicable, shall have the burden of demonstrating that all notifications were made as required by this subpart or that the use or disclosure did not constitute a breach, as defined at § 164.402.

Subpart E—Privacy of Individually Identifiable Health Information

Authority: 42 U.S.C. 1320d-2, 1320d-4, and 1320d-9; sec. 264 of Pub. L. 104-191, 110 Stat. 2033-2034 (42 U.S.C. 1320d-2 (note)); and secs. 13400-13424, Pub. L. 111-5, 123 Stat. 258-279.

§ 164.500 Applicability.

- (a) Except as otherwise provided herein, the standards, requirements, and implementation specifications of this subpart apply to covered entities with respect to protected health information.
- (b) Health care clearinghouses must comply with the standards, requirements, and implementation specifications as follows:
 - (1) When a health care clearinghouse creates or receives protected health information as a business associate of another covered entity, the clearinghouse must comply with:
 - (i) Section 164.500 relating to applicability;
 - (ii) Section 164.501 relating to definitions;
 - (iii) Section 164.502 relating to uses and disclosures of protected health information, except that a clearinghouse is prohibited from using or disclosing protected health information other than as permitted in the business associate contract under which it created or received the protected health information;
 - (iv) Section 164.504 relating to the organizational requirements for covered entities;

(v) Section 164.512 relating to uses and disclosures for which individual authorization or an opportunity to agree or object is not required, except that a clearinghouse is prohibited from using or disclosing protected health information other than as permitted in the business associate contract under which it created or received the protected health information;

(vi) Section 164.532 relating to transition requirements; and

(vii) Section 164.534 relating to compliance dates for initial implementation of the privacy standards.

(2) When a health care clearinghouse creates or receives protected health information other than as a business associate of a covered entity, the clearinghouse must comply with all of the standards, requirements, and implementation specifications of this subpart.

(c) Where provided, the standards, requirements, and implementation specifications adopted under this subpart apply to a business associate with respect to the protected health information of a covered entity.

(d) The standards, requirements, and implementation specifications of this subpart do not apply to the Department of Defense or to any other federal agency, or non-governmental organization acting on its behalf, when providing health care to overseas foreign national beneficiaries.

[65 FR 82802, Dec. 28, 2000, as amended at 67 FR 53266, Aug. 14, 2002; 68 FR 8381, Feb. 20, 2003; 78 FR 5695, Jan. 25, 2013]

§ 164.501 Definitions.

As used in this subpart, the following terms have the following meanings:

Correctional institution means any penal or correctional facility, jail, reformatory, detention center, work farm, halfway house, or residential community program center operated by, or under contract to, the United States, a State, a territory, a political subdivision of a State or territory, or an Indian tribe, for the confinement or rehabilitation of persons charged with or convicted of a criminal offense or other persons held in lawful custody. *Other persons* held in lawful custody includes juvenile offenders adjudicated delinquent, aliens detained awaiting deportation, persons committed to mental institutions through the criminal justice system, witnesses, or others awaiting charges or trial.

Data aggregation means, with respect to protected health information created or received by a business associate in its capacity as the business associate of a covered entity, the combining of such protected health information by the business associate with the protected health information received by the business associate in its capacity as a business associate of another covered entity, to permit data analyses that relate to the health care operations of the respective covered entities.

Designated record set means:

(1) A group of records maintained by or for a covered entity that is:

(i) The medical records and billing records about individuals maintained by or for a covered health care provider;

(ii) The enrollment, payment, claims adjudication, and case or medical management record systems maintained by or for a health plan; or

(iii) Used, in whole or in part, by or for the covered entity to make decisions about individuals.

- (2) For purposes of this paragraph, the term record means any item, collection, or grouping of information that includes protected health information and is maintained, collected, used, or disseminated by or for a covered entity.

Direct treatment relationship means a treatment relationship between an individual and a health care provider that is not an indirect treatment relationship.

Health care operations means any of the following activities of the covered entity to the extent that the activities are related to covered functions:

- (1) Conducting quality assessment and improvement activities, including outcomes evaluation and development of clinical guidelines, provided that the obtaining of generalizable knowledge is not the primary purpose of any studies resulting from such activities; patient safety activities (as defined in 42 CFR 3.20); population-based activities relating to improving health or reducing health care costs, protocol development, case management and care coordination, contacting of health care providers and patients with information about treatment alternatives; and related functions that do not include treatment;
- (2) Reviewing the competence or qualifications of health care professionals, evaluating practitioner and provider performance, health plan performance, conducting training programs in which students, trainees, or practitioners in areas of health care learn under supervision to practice or improve their skills as health care providers, training of non-health care professionals, accreditation, certification, licensing, or credentialing activities;
- (3) Except as prohibited under § 164.502(a)(5)(i), underwriting, enrollment, premium rating, and other activities related to the creation, renewal, or replacement of a contract of health insurance or health benefits, and ceding, securing, or placing a contract for reinsurance of risk relating to claims for health care (including stop-loss insurance and excess of loss insurance), provided that the requirements of § 164.514(g) are met, if applicable;
- (4) Conducting or arranging for medical review, legal services, and auditing functions, including fraud and abuse detection and compliance programs;
- (5) Business planning and development, such as conducting cost-management and planning-related analyses related to managing and operating the entity, including formulary development and administration, development or improvement of methods of payment or coverage policies; and
- (6) Business management and general administrative activities of the entity, including, but not limited to:
 - (i) Management activities relating to implementation of and compliance with the requirements of this subchapter;
 - (ii) Customer service, including the provision of data analyses for policy holders, plan sponsors, or other customers, provided that protected health information is not disclosed to such policy holder, plan sponsor, or customer.
 - (iii) Resolution of internal grievances;
 - (iv) The sale, transfer, merger, or consolidation of all or part of the covered entity with another covered entity, or an entity that following such activity will become a covered entity and due diligence related to such activity; and
 - (v) Consistent with the applicable requirements of § 164.514, creating de-identified health information or a limited data set, and fundraising for the benefit of the covered entity.

Health oversight agency means an agency or authority of the United States, a State, a territory, a political subdivision of a State or territory, or an Indian tribe, or a person or entity acting under a grant of authority from or contract with such public agency, including the employees or agents of such public agency or its contractors or persons or entities to whom it has granted authority, that is authorized by law to oversee the health care system (whether public or private) or government programs in which health information is necessary to determine eligibility or compliance, or to enforce civil rights laws for which health information is relevant.

Indirect treatment relationship means a relationship between an individual and a health care provider in which:

- (1) The health care provider delivers health care to the individual based on the orders of another health care provider; and
- (2) The health care provider typically provides services or products, or reports the diagnosis or results associated with the health care, directly to another health care provider, who provides the services or products or reports to the individual.

Inmate means a person incarcerated in or otherwise confined to a correctional institution.

Marketing:

- (1) Except as provided in paragraph (2) of this definition, marketing means to make a communication about a product or service that encourages recipients of the communication to purchase or use the product or service.
- (2) Marketing does not include a communication made:
 - (i) To provide refill reminders or otherwise communicate about a drug or biologic that is currently being prescribed for the individual, only if any financial remuneration received by the covered entity in exchange for making the communication is reasonably related to the covered entity's cost of making the communication.
 - (ii) For the following treatment and health care operations purposes, except where the covered entity receives financial remuneration in exchange for making the communication:
 - (A) For treatment of an individual by a health care provider, including case management or care coordination for the individual, or to direct or recommend alternative treatments, therapies, health care providers, or settings of care to the individual;
 - (B) To describe a health-related product or service (or payment for such product or service) that is provided by, or included in a plan of benefits of, the covered entity making the communication, including communications about: the entities participating in a health care provider network or health plan network; replacement of, or enhancements to, a health plan; and health-related products or services available only to a health plan enrollee that add value to, but are not part of, a plan of benefits; or
 - (C) For case management or care coordination, contacting of individuals with information about treatment alternatives, and related functions to the extent these activities do not fall within the definition of treatment.
- (3) **Financial remuneration** means direct or indirect payment from or on behalf of a third party whose product or service is being described. Direct or indirect payment does not include any payment for treatment of an individual.

Payment means:

- (1) The activities undertaken by:
 - (i) Except as prohibited under § 164.502(a)(5)(i), a health plan to obtain premiums or to determine or fulfill its responsibility for coverage and provision of benefits under the health plan; or
 - (ii) A health care provider or health plan to obtain or provide reimbursement for the provision of health care; and
- (2) The activities in paragraph (1) of this definition relate to the individual to whom health care is provided and include, but are not limited to:
 - (i) Determinations of eligibility or coverage (including coordination of benefits or the determination of cost sharing amounts), and adjudication or subrogation of health benefit claims;
 - (ii) Risk adjusting amounts due based on enrollee health status and demographic characteristics;
 - (iii) Billing, claims management, collection activities, obtaining payment under a contract for reinsurance (including stop-loss insurance and excess of loss insurance), and related health care data processing;
 - (iv) Review of health care services with respect to medical necessity, coverage under a health plan, appropriateness of care, or justification of charges;
 - (v) Utilization review activities, including precertification and preauthorization of services, concurrent and retrospective review of services; and
 - (vi) Disclosure to consumer reporting agencies of any of the following protected health information relating to collection of premiums or reimbursement:
 - (A) Name and address;
 - (B) Date of birth;
 - (C) Social security number;
 - (D) Payment history;
 - (E) Account number; and
 - (F) Name and address of the health care provider and/or health plan.

Psychotherapy notes means notes recorded (in any medium) by a health care provider who is a mental health professional documenting or analyzing the contents of conversation during a private counseling session or a group, joint, or family counseling session and that are separated from the rest of the individual's medical record. *Psychotherapy notes* excludes medication prescription and monitoring, counseling session start and stop times, the modalities and frequencies of treatment furnished, results of clinical tests, and any summary of the following items: Diagnosis, functional status, the treatment plan, symptoms, prognosis, and progress to date.

Public health authority means an agency or authority of the United States, a State, a territory, a political subdivision of a State or territory, or an Indian tribe, or a person or entity acting under a grant of authority from or contract with such public agency, including the employees or agents of such public agency or its contractors or persons or entities to whom it has granted authority, that is responsible for public health matters as part of its official mandate.

Research means a systematic investigation, including research development, testing, and evaluation, designed to develop or contribute to generalizable knowledge.

Treatment means the provision, coordination, or management of health care and related services by one or more health care providers, including the coordination or management of health care by a health care provider with a third party; consultation between health care providers relating to a patient; or the referral of a patient for health care from one health care provider to another.

[65 FR 82802, Dec. 28, 2000, as amended at 67 FR 53266, Aug. 14, 2002; 68 FR 8381, Feb. 20, 2003; 74 FR 42769, Aug. 24, 2009; 78 FR 5695, Jan. 25, 2013]

§ 164.502 Uses and disclosures of protected health information: General rules.

- (a) **Standard.** A covered entity or business associate may not use or disclose protected health information, except as permitted or required by this subpart or by subpart C of part 160 of this subchapter.
 - (1) **Covered entities: Permitted uses and disclosures.** A covered entity is permitted to use or disclose protected health information as follows:
 - (i) To the individual;
 - (ii) For treatment, payment, or health care operations, as permitted by and in compliance with § 164.506;
 - (iii) Incident to a use or disclosure otherwise permitted or required by this subpart, provided that the covered entity has complied with the applicable requirements of §§ 164.502(b), 164.514(d), and 164.530(c) with respect to such otherwise permitted or required use or disclosure;
 - (iv) Except for uses and disclosures prohibited under § 164.502(a)(5)(i), pursuant to and in compliance with a valid authorization under § 164.508;
 - (v) Pursuant to an agreement under, or as otherwise permitted by, § 164.510; and
 - (vi) As permitted by and in compliance with any of the following:
 - (A) This section.
 - (B) Section 164.512 and, where applicable, § 164.509.
 - (C) Section 164.514(e), (f), or (g).
 - (2) **Covered entities: Required disclosures.** A covered entity is required to disclose protected health information:
 - (i) To an individual, when requested under, and required by § 164.524 or § 164.528; and
 - (ii) When required by the Secretary under subpart C of part 160 of this subchapter to investigate or determine the covered entity's compliance with this subchapter.
 - (3) **Business associates: Permitted uses and disclosures.** A business associate may use or disclose protected health information only as permitted or required by its business associate contract or other arrangement pursuant to § 164.504(e) or as required by law. The business associate may not use or disclose protected health information in a manner that would violate the requirements of this subpart, if done by the covered entity, except for the purposes specified under § 164.504(e)(2)(i)(A) or (B) if such uses or disclosures are permitted by its contract or other arrangement.

- (4) **Business associates: Required uses and disclosures.** A business associate is required to disclose protected health information:
- (i) When required by the Secretary under subpart C of part 160 of this subchapter to investigate or determine the business associate's compliance with this subchapter.
 - (ii) To the covered entity, individual, or individual's designee, as necessary to satisfy a covered entity's obligations under § 164.524(c)(2)(ii) and (3)(ii) with respect to an individual's request for an electronic copy of protected health information.
- (5) **Prohibited uses and disclosures —**
- (i) **Use and disclosure of genetic information for underwriting purposes:** Notwithstanding any other provision of this subpart, a health plan, excluding an issuer of a long-term care policy falling within paragraph (1)(viii) of the definition of *health plan*, shall not use or disclose protected health information that is genetic information for underwriting purposes. For purposes of paragraph (a)(5)(i) of this section, underwriting purposes means, with respect to a health plan:
 - (A) Except as provided in paragraph (a)(5)(i)(B) of this section:
 - (1) Rules for, or determination of, eligibility (including enrollment and continued eligibility) for, or determination of, benefits under the plan, coverage, or policy (including changes in deductibles or other cost-sharing mechanisms in return for activities such as completing a health risk assessment or participating in a wellness program);
 - (2) The computation of premium or contribution amounts under the plan, coverage, or policy (including discounts, rebates, payments in kind, or other premium differential mechanisms in return for activities such as completing a health risk assessment or participating in a wellness program);
 - (3) The application of any pre-existing condition exclusion under the plan, coverage, or policy; and
 - (4) Other activities related to the creation, renewal, or replacement of a contract of health insurance or health benefits.
 - (B) Underwriting purposes does not include determinations of medical appropriateness where an individual seeks a benefit under the plan, coverage, or policy.
 - (ii) **Sale of protected health information:**
 - (A) Except pursuant to and in compliance with § 164.508(a)(4), a covered entity or business associate may not sell protected health information.
 - (B) For purposes of this paragraph, sale of protected health information means:
 - (1) Except as provided in paragraph (a)(5)(ii)(B)(2) of this section, a disclosure of protected health information by a covered entity or business associate, if applicable, where the covered entity or business associate directly or indirectly receives remuneration from or on behalf of the recipient of the protected health information in exchange for the protected health information.
 - (2) Sale of protected health information does not include a disclosure of protected health information:

- (i) For public health purposes pursuant to § 164.512(b) or § 164.514(e);
- (ii) For research purposes pursuant to § 164.512(i) or § 164.514(e), where the only remuneration received by the covered entity or business associate is a reasonable cost-based fee to cover the cost to prepare and transmit the protected health information for such purposes;
- (iii) For treatment and payment purposes pursuant to § 164.506(a);
- (iv) For the sale, transfer, merger, or consolidation of all or part of the covered entity and for related due diligence as described in paragraph (6)(iv) of the definition of health care operations and pursuant to § 164.506(a);
- (v) To or by a business associate for activities that the business associate undertakes on behalf of a covered entity, or on behalf of a business associate in the case of a subcontractor, pursuant to §§ 164.502(e) and 164.504(e), and the only remuneration provided is by the covered entity to the business associate, or by the business associate to the subcontractor, if applicable, for the performance of such activities;
- (vi) To an individual, when requested under § 164.524 or § 164.528;
- (vii) Required by law as permitted under § 164.512(a); and
- (viii) For any other purpose permitted by and in accordance with the applicable requirements of this subpart, where the only remuneration received by the covered entity or business associate is a reasonable, cost-based fee to cover the cost to prepare and transmit the protected health information for such purpose or a fee otherwise expressly permitted by other law.

(iii) **Reproductive health care —**

- (A) **Prohibition.** Subject to paragraphs (a)(5)(iii)(B) and (C) of this section, a covered entity or business associate may not use or disclose protected health information for any of the following activities:
 - (1) To conduct a criminal, civil, or administrative investigation into any person for the mere act of seeking, obtaining, providing, or facilitating reproductive health care.
 - (2) To impose criminal, civil, or administrative liability on any person for the mere act of seeking, obtaining, providing, or facilitating reproductive health care.
 - (3) To identify any person for any purpose described in paragraphs (a)(5)(iii)(A)(1) or (2) of this section.
- (B) **Rule of applicability.** The prohibition at paragraph (a)(5)(iii)(A) of this section applies only where the relevant activity is in connection with any person seeking, obtaining, providing, or facilitating reproductive health care, and the covered entity or business associate that received the request for protected health information has reasonably determined that one or more of the following conditions exists:
 - (1) The reproductive health care is lawful under the law of the state in which such health care is provided under the circumstances in which it is provided.

(2) The reproductive health care is protected, required, or authorized by Federal law, including the United States Constitution, under the circumstances in which such health care is provided, regardless of the state in which it is provided.

(3) The presumption at paragraph (a)(5)(iii)(C) of this section applies.

(C) **Presumption.** The reproductive health care provided by another person is presumed lawful under paragraph (a)(5)(iii)(B)(1) or (2) of this section unless the covered entity or business associate has any of the following:

(1) Actual knowledge that the reproductive health care was not lawful under the circumstances in which it was provided.

(2) Factual information supplied by the person requesting the use or disclosure of protected health information that demonstrates a substantial factual basis that the reproductive health care was not lawful under the specific circumstances in which it was provided.

(D) **Scope.** For the purposes of this subpart, seeking, obtaining, providing, or facilitating reproductive health care includes, but is not limited to, any of the following: expressing interest in, using, performing, furnishing, paying for, disseminating information about, arranging, insuring, administering, authorizing, providing coverage for, approving, counseling about, assisting, or otherwise taking action to engage in reproductive health care; or attempting any of the same.

(b) **Standard: Minimum necessary – Minimum necessary applies.** When using or disclosing protected health information or when requesting protected health information from another covered entity or business associate, a covered entity or business associate must make reasonable efforts to limit protected health information to the minimum necessary to accomplish the intended purpose of the use, disclosure, or request.

(2) **Minimum necessary does not apply.** This requirement does not apply to:

(i) Disclosures to or requests by a health care provider for treatment;

(ii) Uses or disclosures made to the individual, as permitted under paragraph (a)(1)(i) of this section or as required by paragraph (a)(2)(i) of this section;

(iii) Uses or disclosures made pursuant to an authorization under § 164.508;

(iv) Disclosures made to the Secretary in accordance with subpart C of part 160 of this subchapter;

(v) Uses or disclosures that are required by law, as described by § 164.512(a); and

(vi) Uses or disclosures that are required for compliance with applicable requirements of this subchapter.

(c) **Standard: Uses and disclosures of protected health information subject to an agreed upon restriction.** A covered entity that has agreed to a restriction pursuant to § 164.522(a)(1) may not use or disclose the protected health information covered by the restriction in violation of such restriction, except as otherwise provided in § 164.522(a).

(d) **Standard: Uses and disclosures of de-identified protected health information –**

- (1) **Uses and disclosures to create de-identified information.** A covered entity may use protected health information to create information that is not individually identifiable health information or disclose protected health information only to a business associate for such purpose, whether or not the de-identified information is to be used by the covered entity.
- (2) **Uses and disclosures of de-identified information.** Health information that meets the standard and implementation specifications for de-identification under § 164.514(a) and (b) is considered not to be individually identifiable health information, *i.e.*, de-identified. The requirements of this subpart do not apply to information that has been de-identified in accordance with the applicable requirements of § 164.514, provided that:
 - (i) Disclosure of a code or other means of record identification designed to enable coded or otherwise de-identified information to be re-identified constitutes disclosure of protected health information; and
 - (ii) If de-identified information is re-identified, a covered entity may use or disclose such re-identified information only as permitted or required by this subpart.

(e)

- (1) **Standard: Disclosures to business associates.**
 - (i) A covered entity may disclose protected health information to a business associate and may allow a business associate to create, receive, maintain, or transmit protected health information on its behalf, if the covered entity obtains satisfactory assurance that the business associate will appropriately safeguard the information. A covered entity is not required to obtain such satisfactory assurances from a business associate that is a subcontractor.
 - (ii) A business associate may disclose protected health information to a business associate that is a subcontractor and may allow the subcontractor to create, receive, maintain, or transmit protected health information on its behalf, if the business associate obtains satisfactory assurances, in accordance with § 164.504(e)(1)(i), that the subcontractor will appropriately safeguard the information.
- (2) **Implementation specification: Documentation.** The satisfactory assurances required by paragraph (e)(1) of this section must be documented through a written contract or other written agreement or arrangement with the business associate that meets the applicable requirements of § 164.504(e).

- (f) **Standard: Deceased individuals.** A covered entity must comply with the requirements of this subpart with respect to the protected health information of a deceased individual for a period of 50 years following the death of the individual.

(g)

- (1) **Standard: Personal representatives.** As specified in this paragraph, a covered entity must, except as provided in paragraphs (g)(3) and (g)(5) of this section, treat a personal representative as the individual for purposes of this subchapter.
- (2) **Implementation specification: Adults and emancipated minors.** If under applicable law a person has authority to act on behalf of an individual who is an adult or an emancipated minor in making decisions related to health care, a covered entity must treat such person as a personal representative under this subchapter, with respect to protected health information relevant to such personal representation.

(3)

(i) **Implementation specification: Unemancipated minors.** If under applicable law a parent, guardian, or other person acting *in loco parentis* has authority to act on behalf of an individual who is an unemancipated minor in making decisions related to health care, a covered entity must treat such person as a personal representative under this subchapter, with respect to protected health information relevant to such personal representation, except that such person may not be a personal representative of an unemancipated minor, and the minor has the authority to act as an individual, with respect to protected health information pertaining to a health care service, if:

- (A) The minor consents to such health care service; no other consent to such health care service is required by law, regardless of whether the consent of another person has also been obtained; and the minor has not requested that such person be treated as the personal representative;
- (B) The minor may lawfully obtain such health care service without the consent of a parent, guardian, or other person acting *in loco parentis*, and the minor, a court, or another person authorized by law consents to such health care service; or
- (C) A parent, guardian, or other person acting *in loco parentis* assents to an agreement of confidentiality between a covered health care provider and the minor with respect to such health care service.

(ii) Notwithstanding the provisions of paragraph (g)(3)(i) of this section:

- (A) If, and to the extent, permitted or required by an applicable provision of State or other law, including applicable case law, a covered entity may disclose, or provide access in accordance with § 164.524 to, protected health information about an unemancipated minor to a parent, guardian, or other person acting *in loco parentis*;
- (B) If, and to the extent, prohibited by an applicable provision of State or other law, including applicable case law, a covered entity may not disclose, or provide access in accordance with § 164.524 to, protected health information about an unemancipated minor to a parent, guardian, or other person acting *in loco parentis*; and
- (C) Where the parent, guardian, or other person acting *in loco parentis*, is not the personal representative under paragraphs (g)(3)(i)(A), (B), or (C) of this section and where there is no applicable access provision under State or other law, including case law, a covered entity may provide or deny access under § 164.524 to a parent, guardian, or other person acting *in loco parentis*, if such action is consistent with State or other applicable law, provided that such decision must be made by a licensed health care professional, in the exercise of professional judgment.

(4) **Implementation specification: Deceased individuals.** If under applicable law an executor, administrator, or other person has authority to act on behalf of a deceased individual or of the individual's estate, a covered entity must treat such person as a personal representative under this subchapter, with respect to protected health information relevant to such personal representation.

(5) **Implementation specification: Abuse, neglect, endangerment situations.** Notwithstanding a State law or any requirement of this paragraph to the contrary, a covered entity may elect not to treat a person as the personal representative, provided that the conditions at paragraphs (g)(5)(i) and (ii) of this section are met:

(i) Paragraphs (g)(5)(i)(A) and (B) of this section both apply.

(A) The covered entity has a reasonable belief that any of the following is true:

(1) The individual has been or may be subjected to domestic violence, abuse, or neglect by such person.

(2) Treating such person as the personal representative could endanger the individual.

(B) The covered entity, in the exercise of professional judgment, decides that it is not in the best interest of the individual to treat the person as the individual's personal representative.

(ii) The covered entity does not have a reasonable belief under paragraph (g)(5)(i)(A) of this section if the basis for their belief is the provision or facilitation of reproductive health care by such person for and at the request of the individual.

(h) **Standard: Confidential communications.** A covered health care provider or health plan must comply with the applicable requirements of § 164.522(b) in communicating protected health information.

(i) **Standard: Uses and disclosures consistent with notice.** A covered entity that is required by § 164.520 to have a notice may not use or disclose protected health information in a manner inconsistent with such notice. A covered entity that is required by § 164.520(b)(1)(iii) to include a specific statement in its notice if it intends to engage in an activity listed in § 164.520(b)(1)(iii)(A)-(C), may not use or disclose protected health information for such activities, unless the required statement is included in the notice.

(j) **Standard: Disclosures by whistleblowers and workforce member crime victims –**

(1) **Disclosures by whistleblowers.** A covered entity is not considered to have violated the requirements of this subpart if a member of its workforce or a business associate discloses protected health information, provided that:

(i) The workforce member or business associate believes in good faith that the covered entity has engaged in conduct that is unlawful or otherwise violates professional or clinical standards, or that the care, services, or conditions provided by the covered entity potentially endangers one or more patients, workers, or the public; and

(ii) The disclosure is to:

(A) A health oversight agency or public health authority authorized by law to investigate or otherwise oversee the relevant conduct or conditions of the covered entity or to an appropriate health care accreditation organization for the purpose of reporting the allegation of failure to meet professional standards or misconduct by the covered entity; or

(B) An attorney retained by or on behalf of the workforce member or business associate for the purpose of determining the legal options of the workforce member or business associate with regard to the conduct described in paragraph (j)(1)(i) of this section.

- (2) **Disclosures by workforce members who are victims of a crime.** A covered entity is not considered to have violated the requirements of this subpart if a member of its workforce who is the victim of a criminal act discloses protected health information to a law enforcement official, provided that:
- (i) The protected health information disclosed is about the suspected perpetrator of the criminal act; and
 - (ii) The protected health information disclosed is limited to the information listed in § 164.512(f)(2)(i).

[65 FR 82802, Dec. 28, 2000, as amended at 67 FR 53267, Aug. 14, 2002; 78 FR 5696, Jan. 25, 2013; 89 FR 33063, Apr. 26, 2024]

§ 164.504 Uses and disclosures: Organizational requirements.

- (a) **Definitions.** As used in this section:

Plan administration functions means administration functions performed by the plan sponsor of a group health plan on behalf of the group health plan and excludes functions performed by the plan sponsor in connection with any other benefit or benefit plan of the plan sponsor.

Summary health information means information, that may be individually identifiable health information, and:

- (1) That summarizes the claims history, claims expenses, or type of claims experienced by individuals for whom a plan sponsor has provided health benefits under a group health plan; and
- (2) From which the information described at § 164.514(b)(2)(i) has been deleted, except that the geographic information described in § 164.514(b)(2)(i)(B) need only be aggregated to the level of a five digit zip code.

(b)-(d) [Reserved]

(e)

- (1) **Standard: Business associate contracts.**

- (i) The contract or other arrangement required by § 164.502(e)(2) must meet the requirements of paragraph (e)(2), (e)(3), or (e)(5) of this section, as applicable.
- (ii) A covered entity is not in compliance with the standards in § 164.502(e) and this paragraph, if the covered entity knew of a pattern of activity or practice of the business associate that constituted a material breach or violation of the business associate's obligation under the contract or other arrangement, unless the covered entity took reasonable steps to cure the breach or end the violation, as applicable, and, if such steps were unsuccessful, terminated the contract or arrangement, if feasible.
- (iii) A business associate is not in compliance with the standards in § 164.502(e) and this paragraph, if the business associate knew of a pattern of activity or practice of a subcontractor that constituted a material breach or violation of the subcontractor's obligation under the contract or other arrangement, unless the business associate took reasonable steps to cure the breach or end the violation, as applicable, and, if such steps were unsuccessful, terminated the contract or arrangement, if feasible.

- (2) **Implementation specifications: Business associate contracts.** A contract between the covered entity and a business associate must:
- (i) Establish the permitted and required uses and disclosures of protected health information by the business associate. The contract may not authorize the business associate to use or further disclose the information in a manner that would violate the requirements of this subpart, if done by the covered entity, except that:
 - (A) The contract may permit the business associate to use and disclose protected health information for the proper management and administration of the business associate, as provided in paragraph (e)(4) of this section; and
 - (B) The contract may permit the business associate to provide data aggregation services relating to the health care operations of the covered entity.
 - (ii) Provide that the business associate will:
 - (A) Not use or further disclose the information other than as permitted or required by the contract or as required by law;
 - (B) Use appropriate safeguards and comply, where applicable, with subpart C of this part with respect to electronic protected health information, to prevent use or disclosure of the information other than as provided for by its contract;
 - (C) Report to the covered entity any use or disclosure of the information not provided for by its contract of which it becomes aware, including breaches of unsecured protected health information as required by § 164.410;
 - (D) In accordance with § 164.502(e)(1)(ii), ensure that any subcontractors that create, receive, maintain, or transmit protected health information on behalf of the business associate agree to the same restrictions and conditions that apply to the business associate with respect to such information;
 - (E) Make available protected health information in accordance with § 164.524;
 - (F) Make available protected health information for amendment and incorporate any amendments to protected health information in accordance with § 164.526;
 - (G) Make available the information required to provide an accounting of disclosures in accordance with § 164.528;
 - (H) To the extent the business associate is to carry out a covered entity's obligation under this subpart, comply with the requirements of this subpart that apply to the covered entity in the performance of such obligation.
 - (I) Make its internal practices, books, and records relating to the use and disclosure of protected health information received from, or created or received by the business associate on behalf of, the covered entity available to the Secretary for purposes of determining the covered entity's compliance with this subpart; and
 - (J) At termination of the contract, if feasible, return or destroy all protected health information received from, or created or received by the business associate on behalf of, the covered entity that the business associate still maintains in any form and retain no copies of such

information or, if such return or destruction is not feasible, extend the protections of the contract to the information and limit further uses and disclosures to those purposes that make the return or destruction of the information infeasible.

- (iii) Authorize termination of the contract by the covered entity, if the covered entity determines that the business associate has violated a material term of the contract.

(3) **Implementation specifications: Other arrangements.**

- (i) If a covered entity and its business associate are both governmental entities:
 - (A) The covered entity may comply with this paragraph and § 164.314(a)(1), if applicable, by entering into a memorandum of understanding with the business associate that contains terms that accomplish the objectives of paragraph (e)(2) of this section and § 164.314(a)(2), if applicable.
 - (B) The covered entity may comply with this paragraph and § 164.314(a)(1), if applicable, if other law (including regulations adopted by the covered entity or its business associate) contains requirements applicable to the business associate that accomplish the objectives of paragraph (e)(2) of this section and § 164.314(a)(2), if applicable.
- (ii) If a business associate is required by law to perform a function or activity on behalf of a covered entity or to provide a service described in the definition of business associate in § 160.103 of this subchapter to a covered entity, such covered entity may disclose protected health information to the business associate to the extent necessary to comply with the legal mandate without meeting the requirements of this paragraph and § 164.314(a)(1), if applicable, provided that the covered entity attempts in good faith to obtain satisfactory assurances as required by paragraph (e)(2) of this section and § 164.314(a)(1), if applicable, and, if such attempt fails, documents the attempt and the reasons that such assurances cannot be obtained.
- (iii) The covered entity may omit from its other arrangements the termination authorization required by paragraph (e)(2)(iii) of this section, if such authorization is inconsistent with the statutory obligations of the covered entity or its business associate.
- (iv) A covered entity may comply with this paragraph and § 164.314(a)(1) if the covered entity discloses only a limited data set to a business associate for the business associate to carry out a health care operations function and the covered entity has a data use agreement with the business associate that complies with §§ 164.514(e)(4) and 164.314(a)(1), if applicable.

(4) **Implementation specifications: Other requirements for contracts and other arrangements.**

- (i) The contract or other arrangement between the covered entity and the business associate may permit the business associate to use the protected health information received by the business associate in its capacity as a business associate to the covered entity, if necessary:
 - (A) For the proper management and administration of the business associate; or
 - (B) To carry out the legal responsibilities of the business associate.
- (ii) The contract or other arrangement between the covered entity and the business associate may permit the business associate to disclose the protected health information received by the business associate in its capacity as a business associate for the purposes described in paragraph (e)(4)(i) of this section, if:

(A) The disclosure is required by law; or

(B)

(1) The business associate obtains reasonable assurances from the person to whom the information is disclosed that it will be held confidentially and used or further disclosed only as required by law or for the purposes for which it was disclosed to the person; and

(2) The person notifies the business associate of any instances of which it is aware in which the confidentiality of the information has been breached.

(5) **Implementation specifications: Business associate contracts with subcontractors.** The requirements of § 164.504(e)(2) through (e)(4) apply to the contract or other arrangement required by § 164.502(e)(1)(ii) between a business associate and a business associate that is a subcontractor in the same manner as such requirements apply to contracts or other arrangements between a covered entity and business associate.

(f)

(1) **Standard: Requirements for group health plans.**

(i) Except as provided under paragraph (f)(1)(ii) or (iii) of this section or as otherwise authorized under § 164.508, a group health plan, in order to disclose protected health information to the plan sponsor or to provide for or permit the disclosure of protected health information to the plan sponsor by a health insurance issuer or HMO with respect to the group health plan, must ensure that the plan documents restrict uses and disclosures of such information by the plan sponsor consistent with the requirements of this subpart.

(ii) Except as prohibited by § 164.502(a)(5)(i), the group health plan, or a health insurance issuer or HMO with respect to the group health plan, may disclose summary health information to the plan sponsor, if the plan sponsor requests the summary health information for purposes of:

(A) Obtaining premium bids from health plans for providing health insurance coverage under the group health plan; or

(B) Modifying, amending, or terminating the group health plan.

(iii) The group health plan, or a health insurance issuer or HMO with respect to the group health plan, may disclose to the plan sponsor information on whether the individual is participating in the group health plan, or is enrolled in or has disenrolled from a health insurance issuer or HMO offered by the plan.

(2) **Implementation specifications: Requirements for plan documents.** The plan documents of the group health plan must be amended to incorporate provisions to:

(i) Establish the permitted and required uses and disclosures of such information by the plan sponsor, provided that such permitted and required uses and disclosures may not be inconsistent with this subpart.

(ii) Provide that the group health plan will disclose protected health information to the plan sponsor only upon receipt of a certification by the plan sponsor that the plan documents have been amended to incorporate the following provisions and that the plan sponsor agrees to:

- (A) Not use or further disclose the information other than as permitted or required by the plan documents or as required by law;
 - (B) Ensure that any agents to whom it provides protected health information received from the group health plan agree to the same restrictions and conditions that apply to the plan sponsor with respect to such information;
 - (C) Not use or disclose the information for employment-related actions and decisions or in connection with any other benefit or employee benefit plan of the plan sponsor;
 - (D) Report to the group health plan any use or disclosure of the information that is inconsistent with the uses or disclosures provided for of which it becomes aware;
 - (E) Make available protected health information in accordance with § 164.524;
 - (F) Make available protected health information for amendment and incorporate any amendments to protected health information in accordance with § 164.526;
 - (G) Make available the information required to provide an accounting of disclosures in accordance with § 164.528;
 - (H) Make its internal practices, books, and records relating to the use and disclosure of protected health information received from the group health plan available to the Secretary for purposes of determining compliance by the group health plan with this subpart;
 - (I) If feasible, return or destroy all protected health information received from the group health plan that the sponsor still maintains in any form and retain no copies of such information when no longer needed for the purpose for which disclosure was made, except that, if such return or destruction is not feasible, limit further uses and disclosures to those purposes that make the return or destruction of the information infeasible; and
 - (J) Ensure that the adequate separation required in paragraph (f)(2)(iii) of this section is established.
- (iii) Provide for adequate separation between the group health plan and the plan sponsor. The plan documents must:
- (A) Describe those employees or classes of employees or other persons under the control of the plan sponsor to be given access to the protected health information to be disclosed, provided that any employee or person who receives protected health information relating to payment under, health care operations of, or other matters pertaining to the group health plan in the ordinary course of business must be included in such description;
 - (B) Restrict the access to and use by such employees and other persons described in paragraph (f)(2)(iii)(A) of this section to the plan administration functions that the plan sponsor performs for the group health plan; and
 - (C) Provide an effective mechanism for resolving any issues of noncompliance by persons described in paragraph (f)(2)(iii)(A) of this section with the plan document provisions required by this paragraph.

(3) **Implementation specifications: Uses and disclosures.** A group health plan may:

- (i) Disclose protected health information to a plan sponsor to carry out plan administration functions that the plan sponsor performs only consistent with the provisions of paragraph (f)(2) of this section;
- (ii) Not permit a health insurance issuer or HMO with respect to the group health plan to disclose protected health information to the plan sponsor except as permitted by this paragraph;
- (iii) Not disclose and may not permit a health insurance issuer or HMO to disclose protected health information to a plan sponsor as otherwise permitted by this paragraph unless a statement required by § 164.520(b)(1)(iii)(C) is included in the appropriate notice; and
- (iv) Not disclose protected health information to the plan sponsor for the purpose of employment-related actions or decisions or in connection with any other benefit or employee benefit plan of the plan sponsor.

(g) **Standard: Requirements for a covered entity with multiple covered functions.**

- (1) A covered entity that performs multiple covered functions that would make the entity any combination of a health plan, a covered health care provider, and a health care clearinghouse, must comply with the standards, requirements, and implementation specifications of this subpart, as applicable to the health plan, health care provider, or health care clearinghouse covered functions performed.
- (2) A covered entity that performs multiple covered functions may use or disclose the protected health information of individuals who receive the covered entity's health plan or health care provider services, but not both, only for purposes related to the appropriate function being performed.

[65 FR 82802, Dec. 28, 2000, as amended at 67 FR 53267, Aug. 14, 2002; 68 FR 8381, Feb. 20, 2003; 78 FR 5697, Jan. 25, 2013]

§ 164.506 Uses and disclosures to carry out treatment, payment, or health care operations.

- (a) **Standard: Permitted uses and disclosures.** Except with respect to uses or disclosures that require an authorization under § 164.508(a)(2) through (4) or that are prohibited under § 164.502(a)(5)(i), a covered entity may use or disclose protected health information for treatment, payment, or health care operations as set forth in paragraph (c) of this section, provided that such use or disclosure is consistent with other applicable requirements of this subpart.
- (b) **Standard: Consent for uses and disclosures permitted.**
 - (1) A covered entity may obtain consent of the individual to use or disclose protected health information to carry out treatment, payment, or health care operations.
 - (2) Consent, under paragraph (b) of this section, shall not be effective to permit a use or disclosure of protected health information when an authorization, under § 164.508, is required or when another condition must be met for such use or disclosure to be permissible under this subpart.
- (c) **Implementation specifications: Treatment, payment, or health care operations.**
 - (1) A covered entity may use or disclose protected health information for its own treatment, payment, or health care operations.
 - (2) A covered entity may disclose protected health information for treatment activities of a health care provider.

- (3) A covered entity may disclose protected health information to another covered entity or a health care provider for the payment activities of the entity that receives the information.
- (4) A covered entity may disclose protected health information to another covered entity for health care operations activities of the entity that receives the information, if each entity either has or had a relationship with the individual who is the subject of the protected health information being requested, the protected health information pertains to such relationship, and the disclosure is:
 - (i) For a purpose listed in paragraph (1) or (2) of the definition of health care operations; or
 - (ii) For the purpose of health care fraud and abuse detection or compliance.
- (5) A covered entity that participates in an organized health care arrangement may disclose protected health information about an individual to other participants in the organized health care arrangement for any health care operations activities of the organized health care arrangement.

[67 FR 53268, Aug. 14, 2002, as amended at 78 FR 5698, Jan. 25, 2013]

§ 164.508 Uses and disclosures for which an authorization is required.

(a) *Standard: Authorizations for uses and disclosures* —

- (1) **Authorization required: General rule.** Except as otherwise permitted or required by this subchapter, a covered entity may not use or disclose protected health information without an authorization that is valid under this section. When a covered entity obtains or receives a valid authorization for its use or disclosure of protected health information, such use or disclosure must be consistent with such authorization.
- (2) **Authorization required: Psychotherapy notes.** Notwithstanding any provision of this subpart, other than the transition provisions in § 164.532, a covered entity must obtain an authorization for any use or disclosure of psychotherapy notes, except:
 - (i) To carry out the following treatment, payment, or health care operations:
 - (A) Use by the originator of the psychotherapy notes for treatment;
 - (B) Use or disclosure by the covered entity for its own training programs in which students, trainees, or practitioners in mental health learn under supervision to practice or improve their skills in group, joint, family, or individual counseling; or
 - (C) Use or disclosure by the covered entity to defend itself in a legal action or other proceeding brought by the individual; and
 - (ii) A use or disclosure that is required by § 164.502(a)(2)(ii) or permitted by § 164.512(a); § 164.512(d) with respect to the oversight of the originator of the psychotherapy notes; § 164.512(g)(1); or § 164.512(j)(1)(i).
- (3) **Authorization required: Marketing.**
 - (i) Notwithstanding any provision of this subpart, other than the transition provisions in § 164.532, a covered entity must obtain an authorization for any use or disclosure of protected health information for marketing, except if the communication is in the form of:
 - (A) A face-to-face communication made by a covered entity to an individual; or

(B) A promotional gift of nominal value provided by the covered entity.

(ii) If the marketing involves financial remuneration, as defined in paragraph (3) of the definition of marketing at § 164.501, to the covered entity from a third party, the authorization must state that such remuneration is involved.

(4) Authorization required: Sale of protected health information.

(i) Notwithstanding any provision of this subpart, other than the transition provisions in § 164.532, a covered entity must obtain an authorization for any disclosure of protected health information which is a sale of protected health information, as defined in § 164.501 of this subpart.

(ii) Such authorization must state that the disclosure will result in remuneration to the covered entity.

(b) Implementation specifications: General requirements –

(1) Valid authorizations.

(i) A valid authorization is a document that meets the requirements in paragraphs (a)(3)(ii), (a)(4)(ii), (c)(1), and (c)(2) of this section, as applicable.

(ii) A valid authorization may contain elements or information in addition to the elements required by this section, provided that such additional elements or information are not inconsistent with the elements required by this section.

(2) Defective authorizations. An authorization is not valid, if the document submitted has any of the following defects:

(i) The expiration date has passed or the expiration event is known by the covered entity to have occurred;

(ii) The authorization has not been filled out completely, with respect to an element described by paragraph (c) of this section, if applicable;

(iii) The authorization is known by the covered entity to have been revoked;

(iv) The authorization violates paragraph (b)(3) or (4) of this section, if applicable;

(v) Any material information in the authorization is known by the covered entity to be false.

(3) Compound authorizations. An authorization for use or disclosure of protected health information may not be combined with any other document to create a compound authorization, except as follows:

(i) An authorization for the use or disclosure of protected health information for a research study may be combined with any other type of written permission for the same or another research study. This exception includes combining an authorization for the use or disclosure of protected health information for a research study with another authorization for the same research study, with an authorization for the creation or maintenance of a research database or repository, or with a consent to participate in research. Where a covered health care provider has conditioned the provision of research-related treatment on the provision of one of the authorizations, as permitted under paragraph (b)(4)(i) of this section, any compound authorization created under this paragraph must clearly differentiate between the conditioned and unconditioned components and provide the individual with an opportunity to opt in to the research activities described in the unconditioned authorization.

- (ii) An authorization for a use or disclosure of psychotherapy notes may only be combined with another authorization for a use or disclosure of psychotherapy notes.
 - (iii) An authorization under this section, other than an authorization for a use or disclosure of psychotherapy notes, may be combined with any other such authorization under this section, except when a covered entity has conditioned the provision of treatment, payment, enrollment in the health plan, or eligibility for benefits under paragraph (b)(4) of this section on the provision of one of the authorizations. The prohibition in this paragraph on combining authorizations where one authorization conditions the provision of treatment, payment, enrollment in a health plan, or eligibility for benefits under paragraph (b)(4) of this section does not apply to a compound authorization created in accordance with paragraph (b)(3)(i) of this section.
- (4) **Prohibition on conditioning of authorizations.** A covered entity may not condition the provision to an individual of treatment, payment, enrollment in the health plan, or eligibility for benefits on the provision of an authorization, except:
- (i) A covered health care provider may condition the provision of research-related treatment on provision of an authorization for the use or disclosure of protected health information for such research under this section;
 - (ii) A health plan may condition enrollment in the health plan or eligibility for benefits on provision of an authorization requested by the health plan prior to an individual's enrollment in the health plan, if:
 - (A) The authorization sought is for the health plan's eligibility or enrollment determinations relating to the individual or for its underwriting or risk rating determinations; and
 - (B) The authorization is not for a use or disclosure of psychotherapy notes under paragraph (a)(2) of this section; and
 - (iii) A covered entity may condition the provision of health care that is solely for the purpose of creating protected health information for disclosure to a third party on provision of an authorization for the disclosure of the protected health information to such third party.
- (5) **Revocation of authorizations.** An individual may revoke an authorization provided under this section at any time, provided that the revocation is in writing, except to the extent that:
- (i) The covered entity has taken action in reliance thereon; or
 - (ii) If the authorization was obtained as a condition of obtaining insurance coverage, other law provides the insurer with the right to contest a claim under the policy or the policy itself.
- (6) **Documentation.** A covered entity must document and retain any signed authorization under this section as required by § 164.530(j).
- (c) **Implementation specifications: Core elements and requirements –**
- (1) **Core elements.** A valid authorization under this section must contain at least the following elements:
- (i) A description of the information to be used or disclosed that identifies the information in a specific and meaningful fashion.
 - (ii) The name or other specific identification of the person(s), or class of persons, authorized to make the requested use or disclosure.

- (iii) The name or other specific identification of the person(s), or class of persons, to whom the covered entity may make the requested use or disclosure.
 - (iv) A description of each purpose of the requested use or disclosure. The statement “at the request of the individual” is a sufficient description of the purpose when an individual initiates the authorization and does not, or elects not to, provide a statement of the purpose.
 - (v) An expiration date or an expiration event that relates to the individual or the purpose of the use or disclosure. The statement “end of the research study,” “none,” or similar language is sufficient if the authorization is for a use or disclosure of protected health information for research, including for the creation and maintenance of a research database or research repository.
 - (vi) Signature of the individual and date. If the authorization is signed by a personal representative of the individual, a description of such representative's authority to act for the individual must also be provided.
- (2) **Required statements.** In addition to the core elements, the authorization must contain statements adequate to place the individual on notice of all of the following:
- (i) The individual's right to revoke the authorization in writing, and either:
 - (A) The exceptions to the right to revoke and a description of how the individual may revoke the authorization; or
 - (B) To the extent that the information in paragraph (c)(2)(i)(A) of this section is included in the notice required by § 164.520, a reference to the covered entity's notice.
 - (ii) The ability or inability to condition treatment, payment, enrollment or eligibility for benefits on the authorization, by stating either:
 - (A) The covered entity may not condition treatment, payment, enrollment or eligibility for benefits on whether the individual signs the authorization when the prohibition on conditioning of authorizations in paragraph (b)(4) of this section applies; or
 - (B) The consequences to the individual of a refusal to sign the authorization when, in accordance with paragraph (b)(4) of this section, the covered entity can condition treatment, enrollment in the health plan, or eligibility for benefits on failure to obtain such authorization.
 - (iii) The potential for information disclosed pursuant to the authorization to be subject to redisclosure by the recipient and no longer be protected by this subpart.
- (3) **Plain language requirement.** The authorization must be written in plain language.
- (4) **Copy to the individual.** If a covered entity seeks an authorization from an individual for a use or disclosure of protected health information, the covered entity must provide the individual with a copy of the signed authorization.

[67 FR 53268, Aug. 14, 2002, as amended at 78 FR 5699, Jan. 25, 2013]

§ 164.509 Uses and disclosures for which an attestation is required.

- (a) **Standard: Attestations for certain uses and disclosures of protected health information to persons other than covered entities or business associates.**
 - (1) A covered entity or business associate may not use or disclose protected health information potentially related to reproductive health care for purposes specified in § 164.512(d), (e), (f), or (g)(1), without obtaining an attestation that is valid under paragraph (b)(1) of this section from the person requesting the use or disclosure and complying with all applicable conditions of this part.
 - (2) A covered entity or business associate that uses or discloses protected health information potentially related to reproductive health care for purposes specified in § 164.512(d), (e), (f), or (g)(1), in reliance on an attestation that is defective under paragraph (b)(2) of this section, is not in compliance with this section.
- (b) **Implementation specifications: General requirements –**
 - (1) **Valid attestations.**
 - (i) A valid attestation is a document that meets the requirements of paragraph (c)(1) of this section.
 - (ii) A valid attestation verifies that the use or disclosure is not otherwise prohibited by § 164.502(a)(5)(iii).
 - (iii) A valid attestation may be electronic, provided that it meets the requirements in paragraph (c)(1) of this section, as applicable.
 - (2) **Defective attestations.** An attestation is not valid if the document submitted has any of the following defects:
 - (i) The attestation lacks an element or statement required by paragraph (c) of this section.
 - (ii) The attestation contains an element or statement not required by paragraph (c) of this section
 - (iii) The attestation violates paragraph (b)(3) of this section.
 - (iv) The covered entity or business associate has actual knowledge that material information in the attestation is false.
 - (v) A reasonable covered entity or business associate in the same position would not believe that the attestation is true with respect to the requirement at paragraph (c)(1)(iv) of this section.
 - (3) **Compound attestation.** An attestation may not be combined with any other document except where such other document is needed to satisfy the requirements at paragraph (c)(iv) of this section or at § 164.502(a)(5)(iii)(C), as applicable.
- (c) **Implementation specifications: Content requirements and other obligations –**
 - (1) **Required elements.** A valid attestation under this section must contain the following elements:
 - (i) A description of the information requested that identifies the information in a specific fashion, including one of the following:
 - (A) The name of any individual(s) whose protected health information is sought, if practicable.

- (B) If including the name(s) of any individual(s) whose protected health information is sought is not practicable, a description of the class of individuals whose protected health information is sought.
- (ii) The name or other specific identification of the person(s), or class of persons, who are requested to make the use or disclosure.
- (iii) The name or other specific identification of the person(s), or class of persons, to whom the covered entity is to make the requested use or disclosure.
- (iv) A clear statement that the use or disclosure is not for a purpose prohibited under § 164.502(a)(5)(iii).
- (v) A statement that a person may be subject to criminal penalties pursuant to 42 U.S.C. 1320d-6 if that person knowingly and in violation of HIPAA obtains individually identifiable health information relating to an individual or discloses individually identifiable health information to another person.
- (vi) Signature of the person requesting the protected health information, which may be an electronic signature, and date. If the attestation is signed by a representative of the person requesting the information, a description of such representative's authority to act for the person must also be provided.

(2) **Plain language requirement.** The attestation must be written in plain language.

- (d) **Material misrepresentations.** If, during the course of using or disclosing protected health information in reasonable reliance on a facially valid attestation, a covered entity or business associate discovers information reasonably showing that any representation made in the attestation was materially false, leading to a use or disclosure for a purpose prohibited under § 164.502(a)(5)(iii), the covered entity or business associate must cease such use or disclosure.

[89 FR 33063, Apr. 26, 2024]

§ 164.510 Uses and disclosures requiring an opportunity for the individual to agree or to object.

A covered entity may use or disclose protected health information, provided that the individual is informed in advance of the use or disclosure and has the opportunity to agree to or prohibit or restrict the use or disclosure, in accordance with the applicable requirements of this section. The covered entity may orally inform the individual of and obtain the individual's oral agreement or objection to a use or disclosure permitted by this section.

(a) **Standard: Use and disclosure for facility directories —**

- (1) **Permitted uses and disclosure.** Except when an objection is expressed in accordance with paragraphs (a)(2) or (3) of this section, a covered health care provider may:
 - (i) Use the following protected health information to maintain a directory of individuals in its facility:
 - (A) The individual's name;
 - (B) The individual's location in the covered health care provider's facility;
 - (C) The individual's condition described in general terms that does not communicate specific medical information about the individual; and

- (D) The individual's religious affiliation; and
- (ii) Use or disclose for directory purposes such information:
 - (A) To members of the clergy; or
 - (B) Except for religious affiliation, to other persons who ask for the individual by name.
- (2) **Opportunity to object.** A covered health care provider must inform an individual of the protected health information that it may include in a directory and the persons to whom it may disclose such information (including disclosures to clergy of information regarding religious affiliation) and provide the individual with the opportunity to restrict or prohibit some or all of the uses or disclosures permitted by paragraph (a)(1) of this section.
- (3) **Emergency circumstances.**
 - (i) If the opportunity to object to uses or disclosures required by paragraph (a)(2) of this section cannot practicably be provided because of the individual's incapacity or an emergency treatment circumstance, a covered health care provider may use or disclose some or all of the protected health information permitted by paragraph (a)(1) of this section for the facility's directory, if such disclosure is:
 - (A) Consistent with a prior expressed preference of the individual, if any, that is known to the covered health care provider; and
 - (B) In the individual's best interest as determined by the covered health care provider, in the exercise of professional judgment.
 - (ii) The covered health care provider must inform the individual and provide an opportunity to object to uses or disclosures for directory purposes as required by paragraph (a)(2) of this section when it becomes practicable to do so.
- (b) **Standard: Uses and disclosures for involvement in the individual's care and notification purposes –**
 - (1) **Permitted uses and disclosures.**
 - (i) A covered entity may, in accordance with paragraphs (b)(2), (b)(3), or (b)(5) of this section, disclose to a family member, other relative, or a close personal friend of the individual, or any other person identified by the individual, the protected health information directly relevant to such person's involvement with the individual's health care or payment related to the individual's health care.
 - (ii) A covered entity may use or disclose protected health information to notify, or assist in the notification of (including identifying or locating), a family member, a personal representative of the individual, or another person responsible for the care of the individual of the individual's location, general condition, or death. Any such use or disclosure of protected health information for such notification purposes must be in accordance with paragraphs (b)(2), (b)(3), (b)(4), or (b)(5) of this section, as applicable.
 - (2) **Uses and disclosures with the individual present.** If the individual is present for, or otherwise available prior to, a use or disclosure permitted by paragraph (b)(1) of this section and has the capacity to make health care decisions, the covered entity may use or disclose the protected health information if it:
 - (i) Obtains the individual's agreement;

- (ii) Provides the individual with the opportunity to object to the disclosure, and the individual does not express an objection; or
 - (iii) Reasonably infers from the circumstances, based on the exercise of professional judgment, that the individual does not object to the disclosure.
- (3) **Limited uses and disclosures when the individual is not present.** If the individual is not present, or the opportunity to agree or object to the use or disclosure cannot practicably be provided because of the individual's incapacity or an emergency circumstance, the covered entity may, in the exercise of professional judgment, determine whether the disclosure is in the best interests of the individual and, if so, disclose only the protected health information that is directly relevant to the person's involvement with the individual's care or payment related to the individual's health care or needed for notification purposes. A covered entity may use professional judgment and its experience with common practice to make reasonable inferences of the individual's best interest in allowing a person to act on behalf of the individual to pick up filled prescriptions, medical supplies, X-rays, or other similar forms of protected health information.
- (4) **Uses and disclosures for disaster relief purposes.** A covered entity may use or disclose protected health information to a public or private entity authorized by law or by its charter to assist in disaster relief efforts, for the purpose of coordinating with such entities the uses or disclosures permitted by paragraph (b)(1)(ii) of this section. The requirements in paragraphs (b)(2), (b)(3), or (b)(5) of this section apply to such uses and disclosures to the extent that the covered entity, in the exercise of professional judgment, determines that the requirements do not interfere with the ability to respond to the emergency circumstances.
- (5) **Uses and disclosures when the individual is deceased.** If the individual is deceased, a covered entity may disclose to a family member, or other persons identified in paragraph (b)(1) of this section who were involved in the individual's care or payment for health care prior to the individual's death, protected health information of the individual that is relevant to such person's involvement, unless doing so is inconsistent with any prior expressed preference of the individual that is known to the covered entity.

[65 FR 82802, Dec. 28, 2000, as amended at 67 FR 53270, Aug. 14, 2002; 78 FR 5699, Jan. 25, 2013]

§ 164.512 Uses and disclosures for which an authorization or opportunity to agree or object is not required.

Except as provided by § 164.502(a)(5)(iii), a covered entity may use or disclose protected health information without the written authorization of the individual, as described in § 164.508, or the opportunity for the individual to agree or object as described in § 164.510, in the situations covered by this section, subject to the applicable requirements of this section and § 164.509. When the covered entity is required by this section to inform the individual of, or when the individual may agree to, a use or disclosure permitted by this section, the covered entity's information and the individual's agreement may be given verbally.

(a) **Standard: Uses and disclosures required by law.**

- (1) A covered entity may use or disclose protected health information to the extent that such use or disclosure is required by law and the use or disclosure complies with and is limited to the relevant requirements of such law.

- (2) A covered entity must meet the requirements described in paragraph (c), (e), or (f) of this section for uses or disclosures required by law.

(b) **Standard: Uses and disclosures for public health activities —**

- (1) **Permitted uses and disclosures.** A covered entity may use or disclose protected health information for the public health activities and purposes described in this paragraph to:
 - (i) A public health authority that is authorized by law to collect or receive such information for the purpose of preventing or controlling disease, injury, or disability, including, but not limited to, the reporting of disease, injury, vital events such as birth or death, and the conduct of public health surveillance, public health investigations, and public health interventions; or, at the direction of a public health authority, to an official of a foreign government agency that is acting in collaboration with a public health authority;
 - (ii) A public health authority or other appropriate government authority authorized by law to receive reports of child abuse or neglect;
 - (iii) A person subject to the jurisdiction of the Food and Drug Administration (FDA) with respect to an FDA-regulated product or activity for which that person has responsibility, for the purpose of activities related to the quality, safety or effectiveness of such FDA-regulated product or activity. Such purposes include:
 - (A) To collect or report adverse events (or similar activities with respect to food or dietary supplements), product defects or problems (including problems with the use or labeling of a product), or biological product deviations;
 - (B) To track FDA-regulated products;
 - (C) To enable product recalls, repairs, or replacement, or lookback (including locating and notifying individuals who have received products that have been recalled, withdrawn, or are the subject of lookback); or
 - (D) To conduct post marketing surveillance;
 - (iv) A person who may have been exposed to a communicable disease or may otherwise be at risk of contracting or spreading a disease or condition, if the covered entity or public health authority is authorized by law to notify such person as necessary in the conduct of a public health intervention or investigation; or
 - (v) An employer, about an individual who is a member of the workforce of the employer, if:
 - (A) The covered entity is a covered health care provider who provides health care to the individual at the request of the employer:
 - (1) To conduct an evaluation relating to medical surveillance of the workplace; or
 - (2) To evaluate whether the individual has a work-related illness or injury;
 - (B) The protected health information that is disclosed consists of findings concerning a work-related illness or injury or a workplace-related medical surveillance;

- (C) The employer needs such findings in order to comply with its obligations, under 29 CFR parts 1904 through 1928, 30 CFR parts 50 through 90, or under state law having a similar purpose, to record such illness or injury or to carry out responsibilities for workplace medical surveillance; and
- (D) The covered health care provider provides written notice to the individual that protected health information relating to the medical surveillance of the workplace and work-related illnesses and injuries is disclosed to the employer:
 - (1) By giving a copy of the notice to the individual at the time the health care is provided; or
 - (2) If the health care is provided on the work site of the employer, by posting the notice in a prominent place at the location where the health care is provided.
- (vi) A school, about an individual who is a student or prospective student of the school, if:
 - (A) The protected health information that is disclosed is limited to proof of immunization;
 - (B) The school is required by State or other law to have such proof of immunization prior to admitting the individual; and
 - (C) The covered entity obtains and documents the agreement to the disclosure from either:
 - (1) A parent, guardian, or other person acting *in loco parentis* of the individual, if the individual is an unemancipated minor; or
 - (2) The individual, if the individual is an adult or emancipated minor.
- (2) **Permitted uses.** If the covered entity also is a public health authority, the covered entity is permitted to use protected health information in all cases in which it is permitted to disclose such information for public health activities under paragraph (b)(1) of this section.
- (c) **Standard: Disclosures about victims of abuse, neglect, or domestic violence –**
 - (1) **Permitted disclosures.** Except for reports of child abuse or neglect permitted by paragraph (b)(1)(ii) of this section, a covered entity may disclose protected health information about an individual whom the covered entity reasonably believes to be a victim of abuse, neglect, or domestic violence to a government authority, including a social service or protective services agency, authorized by law to receive reports of such abuse, neglect, or domestic violence:
 - (i) To the extent the disclosure is required by law and the disclosure complies with and is limited to the relevant requirements of such law;
 - (ii) If the individual agrees to the disclosure; or
 - (iii) To the extent the disclosure is expressly authorized by statute or regulation and:
 - (A) The covered entity, in the exercise of professional judgment, believes the disclosure is necessary to prevent serious harm to the individual or other potential victims; or
 - (B) If the individual is unable to agree because of incapacity, a law enforcement or other public official authorized to receive the report represents that the protected health information for which disclosure is sought is not intended to be used against the

individual and that an immediate enforcement activity that depends upon the disclosure would be materially and adversely affected by waiting until the individual is able to agree to the disclosure.

- (2) **Informing the individual.** A covered entity that makes a disclosure permitted by paragraph (c)(1) of this section must promptly inform the individual that such a report has been or will be made, except if:
 - (i) The covered entity, in the exercise of professional judgment, believes informing the individual would place the individual at risk of serious harm; or
 - (ii) The covered entity would be informing a personal representative, and the covered entity reasonably believes the personal representative is responsible for the abuse, neglect, or other injury, and that informing such person would not be in the best interests of the individual as determined by the covered entity, in the exercise of professional judgment.
- (3) **Rule of construction.** Nothing in this section shall be construed to permit disclosures prohibited by § 164.502(a)(5)(iii) when the sole basis of the report of abuse, neglect, or domestic violence is the provision or facilitation of reproductive health care.

(d) **Standard: Uses and disclosures for health oversight activities –**

- (1) **Permitted disclosures.** A covered entity may disclose protected health information to a health oversight agency for oversight activities authorized by law, including audits; civil, administrative, or criminal investigations; inspections; licensure or disciplinary actions; civil, administrative, or criminal proceedings or actions; or other activities necessary for appropriate oversight of:
 - (i) The health care system;
 - (ii) Government benefit programs for which health information is relevant to beneficiary eligibility;
 - (iii) Entities subject to government regulatory programs for which health information is necessary for determining compliance with program standards; or
 - (iv) Entities subject to civil rights laws for which health information is necessary for determining compliance.
- (2) **Exception to health oversight activities.** For the purpose of the disclosures permitted by paragraph (d)(1) of this section, a health oversight activity does not include an investigation or other activity in which the individual is the subject of the investigation or activity and such investigation or other activity does not arise out of and is not directly related to:
 - (i) The receipt of health care;
 - (ii) A claim for public benefits related to health; or
 - (iii) Qualification for, or receipt of, public benefits or services when a patient's health is integral to the claim for public benefits or services.
- (3) **Joint activities or investigations.** Notwithstanding paragraph (d)(2) of this section, if a health oversight activity or investigation is conducted in conjunction with an oversight activity or investigation relating to a claim for public benefits not related to health, the joint activity or investigation is considered a health oversight activity for purposes of paragraph (d) of this section.

- (4) **Permitted uses.** If a covered entity also is a health oversight agency, the covered entity may use protected health information for health oversight activities as permitted by paragraph (d) of this section.

(e) **Standard: Disclosures for judicial and administrative proceedings –**

- (1) **Permitted disclosures.** A covered entity may disclose protected health information in the course of any judicial or administrative proceeding:
 - (i) In response to an order of a court or administrative tribunal, provided that the covered entity discloses only the protected health information expressly authorized by such order; or
 - (ii) In response to a subpoena, discovery request, or other lawful process, that is not accompanied by an order of a court or administrative tribunal, if:
 - (A) The covered entity receives satisfactory assurance, as described in paragraph (e)(1)(iii) of this section, from the party seeking the information that reasonable efforts have been made by such party to ensure that the individual who is the subject of the protected health information that has been requested has been given notice of the request; or
 - (B) The covered entity receives satisfactory assurance, as described in paragraph (e)(1)(iv) of this section, from the party seeking the information that reasonable efforts have been made by such party to secure a qualified protective order that meets the requirements of paragraph (e)(1)(v) of this section.
 - (iii) For the purposes of paragraph (e)(1)(ii)(A) of this section, a covered entity receives satisfactory assurances from a party seeking protected health information if the covered entity receives from such party a written statement and accompanying documentation demonstrating that:
 - (A) The party requesting such information has made a good faith attempt to provide written notice to the individual (or, if the individual's location is unknown, to mail a notice to the individual's last known address);
 - (B) The notice included sufficient information about the litigation or proceeding in which the protected health information is requested to permit the individual to raise an objection to the court or administrative tribunal; and
 - (C) The time for the individual to raise objections to the court or administrative tribunal has elapsed, and:
 - (1) No objections were filed; or
 - (2) All objections filed by the individual have been resolved by the court or the administrative tribunal and the disclosures being sought are consistent with such resolution.
 - (iv) For the purposes of paragraph (e)(1)(ii)(B) of this section, a covered entity receives satisfactory assurances from a party seeking protected health information, if the covered entity receives from such party a written statement and accompanying documentation demonstrating that:
 - (A) The parties to the dispute giving rise to the request for information have agreed to a qualified protective order and have presented it to the court or administrative tribunal with jurisdiction over the dispute; or

- (B) The party seeking the protected health information has requested a qualified protective order from such court or administrative tribunal.
 - (v) For purposes of paragraph (e)(1) of this section, a qualified protective order means, with respect to protected health information requested under paragraph (e)(1)(ii) of this section, an order of a court or of an administrative tribunal or a stipulation by the parties to the litigation or administrative proceeding that:
 - (A) Prohibits the parties from using or disclosing the protected health information for any purpose other than the litigation or proceeding for which such information was requested; and
 - (B) Requires the return to the covered entity or destruction of the protected health information (including all copies made) at the end of the litigation or proceeding.
 - (vi) Notwithstanding paragraph (e)(1)(ii) of this section, a covered entity may disclose protected health information in response to lawful process described in paragraph (e)(1)(ii) of this section without receiving satisfactory assurance under paragraph (e)(1)(ii)(A) or (B) of this section, if the covered entity makes reasonable efforts to provide notice to the individual sufficient to meet the requirements of paragraph (e)(1)(iii) of this section or to seek a qualified protective order sufficient to meet the requirements of paragraph (e)(1)(v) of this section.
- (2) **Other uses and disclosures under this section.** The provisions of this paragraph do not supersede other provisions of this section that otherwise permit or restrict uses or disclosures of protected health information.
- (f) **Standard: Disclosures for law enforcement purposes.** A covered entity may disclose protected health information for a law enforcement purpose to a law enforcement official if the conditions in paragraphs (f)(1) through (f)(6) of this section are met, as applicable.
- (1) **Permitted disclosures: Pursuant to process and as otherwise required by law.** A covered entity may disclose protected health information:
- (i) As required by law including laws that require the reporting of certain types of wounds or other physical injuries, except for laws subject to paragraph (b)(1)(ii) or (c)(1)(i) of this section; or
 - (ii) In compliance with and as limited by the relevant requirements of:
 - (A) A court order or court-ordered warrant, or a subpoena or summons issued by a judicial officer;
 - (B) A grand jury subpoena; or
 - (C) An administrative request for which response is required by law, including an administrative subpoena or summons, a civil or an authorized investigative demand, or similar process authorized under law, provided that:
 - (1) The information sought is relevant and material to a legitimate law enforcement inquiry;
 - (2) The request is specific and limited in scope to the extent reasonably practicable in light of the purpose for which the information is sought; and
 - (3) De-identified information could not reasonably be used.

- (2) **Permitted disclosures: Limited information for identification and location purposes.** Except for disclosures required by law as permitted by paragraph (f)(1) of this section, a covered entity may disclose protected health information in response to a law enforcement official's request for such information for the purpose of identifying or locating a suspect, fugitive, material witness, or missing person, provided that:
- (i) The covered entity may disclose only the following information:
 - (A) Name and address;
 - (B) Date and place of birth;
 - (C) Social security number;
 - (D) ABO blood type and rh factor;
 - (E) Type of injury;
 - (F) Date and time of treatment;
 - (G) Date and time of death, if applicable; and
 - (H) A description of distinguishing physical characteristics, including height, weight, gender, race, hair and eye color, presence or absence of facial hair (beard or moustache), scars, and tattoos.
 - (ii) Except as permitted by paragraph (f)(2)(i) of this section, the covered entity may not disclose for the purposes of identification or location under paragraph (f)(2) of this section any protected health information related to the individual's DNA or DNA analysis, dental records, or typing, samples or analysis of body fluids or tissue.
- (3) **Permitted disclosure: Victims of a crime.** Except for disclosures required by law as permitted by paragraph (f)(1) of this section, a covered entity may disclose protected health information in response to a law enforcement official's request for such information about an individual who is or is suspected to be a victim of a crime, other than disclosures that are subject to paragraph (b) or (c) of this section, if:
- (i) The individual agrees to the disclosure; or
 - (ii) The covered entity is unable to obtain the individual's agreement because of incapacity or other emergency circumstance, provided that:
 - (A) The law enforcement official represents that such information is needed to determine whether a violation of law by a person other than the victim has occurred, and such information is not intended to be used against the victim;
 - (B) The law enforcement official represents that immediate law enforcement activity that depends upon the disclosure would be materially and adversely affected by waiting until the individual is able to agree to the disclosure; and
 - (C) The disclosure is in the best interests of the individual as determined by the covered entity, in the exercise of professional judgment.

- (4) **Permitted disclosure: Decedents.** A covered entity may disclose protected health information about an individual who has died to a law enforcement official for the purpose of alerting law enforcement of the death of the individual if the covered entity has a suspicion that such death may have resulted from criminal conduct.
- (5) **Permitted disclosure: Crime on premises.** A covered entity may disclose to a law enforcement official protected health information that the covered entity believes in good faith constitutes evidence of criminal conduct that occurred on the premises of the covered entity.
- (6) **Permitted disclosure: Reporting crime in emergencies.**

- (i) A covered health care provider providing emergency health care in response to a medical emergency, other than such emergency on the premises of the covered health care provider, may disclose protected health information to a law enforcement official if such disclosure appears necessary to alert law enforcement to:
 - (A) The commission and nature of a crime;
 - (B) The location of such crime or of the victim(s) of such crime; and
 - (C) The identity, description, and location of the perpetrator of such crime.
- (ii) If a covered health care provider believes that the medical emergency described in paragraph (f)(6)(i) of this section is the result of abuse, neglect, or domestic violence of the individual in need of emergency health care, paragraph (f)(6)(i) of this section does not apply and any disclosure to a law enforcement official for law enforcement purposes is subject to paragraph (c) of this section.

(g) **Standard: Uses and disclosures about decedents –**

- (1) **Coroners and medical examiners.** A covered entity may disclose protected health information to a coroner or medical examiner for the purpose of identifying a deceased person, determining a cause of death, or other duties as authorized by law. A covered entity that also performs the duties of a coroner or medical examiner may use protected health information for the purposes described in this paragraph.
- (2) **Funeral directors.** A covered entity may disclose protected health information to funeral directors, consistent with applicable law, as necessary to carry out their duties with respect to the decedent. If necessary for funeral directors to carry out their duties, the covered entity may disclose the protected health information prior to, and in reasonable anticipation of, the individual's death.

(h) **Standard: Uses and disclosures for cadaveric organ, eye or tissue donation purposes.** A covered entity may use or disclose protected health information to organ procurement organizations or other entities engaged in the procurement, banking, or transplantation of cadaveric organs, eyes, or tissue for the purpose of facilitating organ, eye or tissue donation and transplantation.

(i) **Standard: Uses and disclosures for research purposes –**

- (1) **Permitted uses and disclosures.** A covered entity may use or disclose protected health information for research, regardless of the source of funding of the research, provided that:
 - (i) **Board approval of a waiver of authorization.** The covered entity obtains documentation that an alteration to or waiver, in whole or in part, of the individual authorization required by § 164.508 for use or disclosure of protected health information has been approved by either:

- (A) An Institutional Review Board (IRB), established in accordance with 7 CFR 1c.107, 10 CFR 745.107, 14 CFR 1230.107, 15 CFR 27.107, 16 CFR 1028.107, 21 CFR 56.107, 22 CFR 225.107, 24 CFR 60.107, 28 CFR 46.107, 32 CFR 219.107, 34 CFR 97.107, 38 CFR 16.107, 40 CFR 26.107, 45 CFR 46.107, 45 CFR 690.107, or 49 CFR 11.107; or
- (B) A privacy board that:
 - (1) Has members with varying backgrounds and appropriate professional competency as necessary to review the effect of the research protocol on the individual's privacy rights and related interests;
 - (2) Includes at least one member who is not affiliated with the covered entity, not affiliated with any entity conducting or sponsoring the research, and not related to any person who is affiliated with any of such entities; and
 - (3) Does not have any member participating in a review of any project in which the member has a conflict of interest.
- (ii) **Reviews preparatory to research.** The covered entity obtains from the researcher representations that:
 - (A) Use or disclosure is sought solely to review protected health information as necessary to prepare a research protocol or for similar purposes preparatory to research;
 - (B) No protected health information is to be removed from the covered entity by the researcher in the course of the review; and
 - (C) The protected health information for which use or access is sought is necessary for the research purposes.
- (iii) **Research on decedent's information.** The covered entity obtains from the researcher:
 - (A) Representation that the use or disclosure sought is solely for research on the protected health information of decedents;
 - (B) Documentation, at the request of the covered entity, of the death of such individuals; and
 - (C) Representation that the protected health information for which use or disclosure is sought is necessary for the research purposes.
- (2) **Documentation of waiver approval.** For a use or disclosure to be permitted based on documentation of approval of an alteration or waiver, under paragraph (i)(1)(i) of this section, the documentation must include all of the following:
 - (i) **Identification and date of action.** A statement identifying the IRB or privacy board and the date on which the alteration or waiver of authorization was approved;
 - (ii) **Waiver criteria.** A statement that the IRB or privacy board has determined that the alteration or waiver, in whole or in part, of authorization satisfies the following criteria:
 - (A) The use or disclosure of protected health information involves no more than a minimal risk to the privacy of individuals, based on, at least, the presence of the following elements;
 - (1) An adequate plan to protect the identifiers from improper use and disclosure;

- (2) An adequate plan to destroy the identifiers at the earliest opportunity consistent with conduct of the research, unless there is a health or research justification for retaining the identifiers or such retention is otherwise required by law; and
 - (3) Adequate written assurances that the protected health information will not be reused or disclosed to any other person or entity, except as required by law, for authorized oversight of the research study, or for other research for which the use or disclosure of protected health information would be permitted by this subpart;
 - (B) The research could not practicably be conducted without the waiver or alteration; and
 - (C) The research could not practicably be conducted without access to and use of the protected health information.
- (iii) **Protected health information needed.** A brief description of the protected health information for which use or access has been determined to be necessary by the institutional review board or privacy board, pursuant to paragraph (i)(2)(ii)(C) of this section;
- (iv) **Review and approval procedures.** A statement that the alteration or waiver of authorization has been reviewed and approved under either normal or expedited review procedures, as follows:
- (A) An IRB must follow the requirements of the Common Rule, including the normal review procedures (7 CFR 1c.108(b), 10 CFR 745.108(b), 14 CFR 1230.108(b), 15 CFR 27.108(b), 16 CFR 1028.108(b), 21 CFR 56.108(b), 22 CFR 225.108(b), 24 CFR 60.108(b), 28 CFR 46.108(b), 32 CFR 219.108(b), 34 CFR 97.108(b), 38 CFR 16.108(b), 40 CFR 26.108(b), 45 CFR 46.108(b), 45 CFR 690.108(b), or 49 CFR 11.108(b)) or the expedited review procedures (7 CFR 1c.110, 10 CFR 745.110, 14 CFR 1230.110, 15 CFR 27.110, 16 CFR 1028.110, 21 CFR 56.110, 22 CFR 225.110, 24 CFR 60.110, 28 CFR 46.110, 32 CFR 219.110, 34 CFR 97.110, 38 CFR 16.110, 40 CFR 26.110, 45 CFR 46.110, 45 CFR 690.110, or 49 CFR 11.110);
 - (B) A privacy board must review the proposed research at convened meetings at which a majority of the privacy board members are present, including at least one member who satisfies the criterion stated in paragraph (i)(1)(i)(B)(2) of this section, and the alteration or waiver of authorization must be approved by the majority of the privacy board members present at the meeting, unless the privacy board elects to use an expedited review procedure in accordance with paragraph (i)(2)(iv)(C) of this section;
 - (C) A privacy board may use an expedited review procedure if the research involves no more than minimal risk to the privacy of the individuals who are the subject of the protected health information for which use or disclosure is being sought. If the privacy board elects to use an expedited review procedure, the review and approval of the alteration or waiver of authorization may be carried out by the chair of the privacy board, or by one or more members of the privacy board as designated by the chair; and
- (v) **Required signature.** The documentation of the alteration or waiver of authorization must be signed by the chair or other member, as designated by the chair, of the IRB or the privacy board, as applicable.
- (j) **Standard: Uses and disclosures to avert a serious threat to health or safety –**

- (1) **Permitted disclosures.** A covered entity may, consistent with applicable law and standards of ethical conduct, use or disclose protected health information, if the covered entity, in good faith, believes the use or disclosure:
 - (i)
 - (A) Is necessary to prevent or lessen a serious and imminent threat to the health or safety of a person or the public; and
 - (B) Is to a person or persons reasonably able to prevent or lessen the threat, including the target of the threat; or
 - (ii) Is necessary for law enforcement authorities to identify or apprehend an individual:
 - (A) Because of a statement by an individual admitting participation in a violent crime that the covered entity reasonably believes may have caused serious physical harm to the victim; or
 - (B) Where it appears from all the circumstances that the individual has escaped from a correctional institution or from lawful custody, as those terms are defined in § 164.501.
- (2) **Use or disclosure not permitted.** A use or disclosure pursuant to paragraph (j)(1)(ii)(A) of this section may not be made if the information described in paragraph (j)(1)(ii)(A) of this section is learned by the covered entity:
 - (i) In the course of treatment to affect the propensity to commit the criminal conduct that is the basis for the disclosure under paragraph (j)(1)(ii)(A) of this section, or counseling or therapy; or
 - (ii) Through a request by the individual to initiate or to be referred for the treatment, counseling, or therapy described in paragraph (j)(2)(i) of this section.
- (3) **Limit on information that may be disclosed.** A disclosure made pursuant to paragraph (j)(1)(ii)(A) of this section shall contain only the statement described in paragraph (j)(1)(ii)(A) of this section and the protected health information described in paragraph (f)(2)(i) of this section.
- (4) **Presumption of good faith belief.** A covered entity that uses or discloses protected health information pursuant to paragraph (j)(1) of this section is presumed to have acted in good faith with regard to a belief described in paragraph (j)(1)(i) or (ii) of this section, if the belief is based upon the covered entity's actual knowledge or in reliance on a credible representation by a person with apparent knowledge or authority.
- (k) **Standard: Uses and disclosures for specialized government functions –**
 - (1) **Military and veterans activities –**
 - (i) **Armed Forces personnel.** A covered entity may use and disclose the protected health information of individuals who are Armed Forces personnel for activities deemed necessary by appropriate military command authorities to assure the proper execution of the military mission, if the appropriate military authority has published by notice in the FEDERAL REGISTER the following information:
 - (A) Appropriate military command authorities; and
 - (B) The purposes for which the protected health information may be used or disclosed.

- (ii) ***Separation or discharge from military service.*** A covered entity that is a component of the Departments of Defense or Homeland Security may disclose to the Department of Veterans Affairs (DVA) the protected health information of an individual who is a member of the Armed Forces upon the separation or discharge of the individual from military service for the purpose of a determination by DVA of the individual's eligibility for or entitlement to benefits under laws administered by the Secretary of Veterans Affairs.
- (iii) ***Veterans.*** A covered entity that is a component of the Department of Veterans Affairs may use and disclose protected health information to components of the Department that determine eligibility for or entitlement to, or that provide, benefits under the laws administered by the Secretary of Veterans Affairs.
- (iv) ***Foreign military personnel.*** A covered entity may use and disclose the protected health information of individuals who are foreign military personnel to their appropriate foreign military authority for the same purposes for which uses and disclosures are permitted for Armed Forces personnel under the notice published in the FEDERAL REGISTER pursuant to paragraph (k)(1)(i) of this section.
- (2) ***National security and intelligence activities.*** A covered entity may disclose protected health information to authorized federal officials for the conduct of lawful intelligence, counter-intelligence, and other national security activities authorized by the National Security Act (50 U.S.C. 401, et seq.) and implementing authority (e.g., Executive Order 12333).
- (3) ***Protective services for the President and others.*** A covered entity may disclose protected health information to authorized Federal officials for the provision of protective services to the President or other persons authorized by 18 U.S.C. 3056 or to foreign heads of state or other persons authorized by 22 U.S.C. 2709(a)(3), or for the conduct of investigations authorized by 18 U.S.C. 871 and 879.
- (4) ***Medical suitability determinations.*** A covered entity that is a component of the Department of State may use protected health information to make medical suitability determinations and may disclose whether or not the individual was determined to be medically suitable to the officials in the Department of State who need access to such information for the following purposes:
 - (i) For the purpose of a required security clearance conducted pursuant to Executive Orders 10450 and 12968;
 - (ii) As necessary to determine worldwide availability or availability for mandatory service abroad under sections 101(a)(4) and 504 of the Foreign Service Act; or
 - (iii) For a family to accompany a Foreign Service member abroad, consistent with section 101(b)(5) and 904 of the Foreign Service Act.
- (5) ***Correctional institutions and other law enforcement custodial situations –***
 - (i) ***Permitted disclosures.*** A covered entity may disclose to a correctional institution or a law enforcement official having lawful custody of an inmate or other individual protected health information about such inmate or individual, if the correctional institution or such law enforcement official represents that such protected health information is necessary for:
 - (A) The provision of health care to such individuals;
 - (B) The health and safety of such individual or other inmates;

- (C) The health and safety of the officers or employees of or others at the correctional institution;
 - (D) The health and safety of such individuals and officers or other persons responsible for the transporting of inmates or their transfer from one institution, facility, or setting to another;
 - (E) Law enforcement on the premises of the correctional institution; or
 - (F) The administration and maintenance of the safety, security, and good order of the correctional institution.
 - (ii) **Permitted uses.** A covered entity that is a correctional institution may use protected health information of individuals who are inmates for any purpose for which such protected health information may be disclosed.
 - (iii) **No application after release.** For the purposes of this provision, an individual is no longer an inmate when released on parole, probation, supervised release, or otherwise is no longer in lawful custody.
- (6) **Covered entities that are government programs providing public benefits.**
- (i) A health plan that is a government program providing public benefits may disclose protected health information relating to eligibility for or enrollment in the health plan to another agency administering a government program providing public benefits if the sharing of eligibility or enrollment information among such government agencies or the maintenance of such information in a single or combined data system accessible to all such government agencies is required or expressly authorized by statute or regulation.
 - (ii) A covered entity that is a government agency administering a government program providing public benefits may disclose protected health information relating to the program to another covered entity that is a government agency administering a government program providing public benefits if the programs serve the same or similar populations and the disclosure of protected health information is necessary to coordinate the covered functions of such programs or to improve administration and management relating to the covered functions of such programs.
- (7) **National Instant Criminal Background Check System.** A covered entity may use or disclose protected health information for purposes of reporting to the National Instant Criminal Background Check System the identity of an individual who is prohibited from possessing a firearm under 18 U.S.C. 922(g)(4), provided the covered entity:
- (i) Is a State agency or other entity that is, or contains an entity that is:
 - (A) An entity designated by the State to report, or which collects information for purposes of reporting, on behalf of the State, to the National Instant Criminal Background Check System; or
 - (B) A court, board, commission, or other lawful authority that makes the commitment or adjudication that causes an individual to become subject to 18 U.S.C. 922(g)(4); and
 - (ii) Discloses the information only to:
 - (A) The National Instant Criminal Background Check System; or

- (B) An entity designated by the State to report, or which collects information for purposes of reporting, on behalf of the State, to the National Instant Criminal Background Check System; and

(iii)

- (A) Discloses only the limited demographic and certain other information needed for purposes of reporting to the National Instant Criminal Background Check System; and
- (B) Does not disclose diagnostic or clinical information for such purposes.

- (l) **Standard: Disclosures for workers' compensation.** A covered entity may disclose protected health information as authorized by and to the extent necessary to comply with laws relating to workers' compensation or other similar programs, established by law, that provide benefits for work-related injuries or illness without regard to fault.

[65 FR 82802, Dec. 28, 2000, as amended at 67 FR 53270, Aug. 14, 2002; 78 FR 5699, Jan. 25, 2013; 78 FR 34266, June 7, 2013; 81 FR 395, Jan. 6, 2016; 89 FR 33064, Apr. 26, 2024]

§ 164.514 Other requirements relating to uses and disclosures of protected health information.

- (a) **Standard: De-identification of protected health information.** Health information that does not identify an individual and with respect to which there is no reasonable basis to believe that the information can be used to identify an individual is not individually identifiable health information.
- (b) **Implementation specifications: Requirements for de-identification of protected health information.** A covered entity may determine that health information is not individually identifiable health information only if:
 - (1) A person with appropriate knowledge of and experience with generally accepted statistical and scientific principles and methods for rendering information not individually identifiable:
 - (i) Applying such principles and methods, determines that the risk is very small that the information could be used, alone or in combination with other reasonably available information, by an anticipated recipient to identify an individual who is a subject of the information; and
 - (ii) Documents the methods and results of the analysis that justify such determination; or
 - (2)
 - (i) The following identifiers of the individual or of relatives, employers, or household members of the individual, are removed:
 - (A) Names;
 - (B) All geographic subdivisions smaller than a State, including street address, city, county, precinct, zip code, and their equivalent geocodes, except for the initial three digits of a zip code if, according to the current publicly available data from the Bureau of the Census:
 - (1) The geographic unit formed by combining all zip codes with the same three initial digits contains more than 20,000 people; and
 - (2) The initial three digits of a zip code for all such geographic units containing 20,000 or fewer people is changed to 000.

- (C) All elements of dates (except year) for dates directly related to an individual, including birth date, admission date, discharge date, date of death; and all ages over 89 and all elements of dates (including year) indicative of such age, except that such ages and elements may be aggregated into a single category of age 90 or older;
 - (D) Telephone numbers;
 - (E) Fax numbers;
 - (F) Electronic mail addresses;
 - (G) Social security numbers;
 - (H) Medical record numbers;
 - (I) Health plan beneficiary numbers;
 - (J) Account numbers;
 - (K) Certificate/license numbers;
 - (L) Vehicle identifiers and serial numbers, including license plate numbers;
 - (M) Device identifiers and serial numbers;
 - (N) Web Universal Resource Locators (URLs);
 - (O) Internet Protocol (IP) address numbers;
 - (P) Biometric identifiers, including finger and voice prints;
 - (Q) Full face photographic images and any comparable images; and
 - (R) Any other unique identifying number, characteristic, or code, except as permitted by paragraph (c) of this section; and
 - (ii) The covered entity does not have actual knowledge that the information could be used alone or in combination with other information to identify an individual who is a subject of the information.
- (c) **Implementation specifications: Re-identification.** A covered entity may assign a code or other means of record identification to allow information de-identified under this section to be re-identified by the covered entity, provided that:
- (1) **Derivation.** The code or other means of record identification is not derived from or related to information about the individual and is not otherwise capable of being translated so as to identify the individual; and
 - (2) **Security.** The covered entity does not use or disclose the code or other means of record identification for any other purpose, and does not disclose the mechanism for re-identification.
- (d)
- (1) **Standard: minimum necessary requirements.** In order to comply with § 164.502(b) and this section, a covered entity must meet the requirements of paragraphs (d)(2) through (d)(5) of this section with respect to a request for, or the use and disclosure of, protected health information.
 - (2) **Implementation specifications: Minimum necessary uses of protected health information.**

- (i) A covered entity must identify:
 - (A) Those persons or classes of persons, as appropriate, in its workforce who need access to protected health information to carry out their duties; and
 - (B) For each such person or class of persons, the category or categories of protected health information to which access is needed and any conditions appropriate to such access.
- (ii) A covered entity must make reasonable efforts to limit the access of such persons or classes identified in paragraph (d)(2)(i)(A) of this section to protected health information consistent with paragraph (d)(2)(i)(B) of this section.

(3) *Implementation specification: Minimum necessary disclosures of protected health information.*

- (i) For any type of disclosure that it makes on a routine and recurring basis, a covered entity must implement policies and procedures (which may be standard protocols) that limit the protected health information disclosed to the amount reasonably necessary to achieve the purpose of the disclosure.
- (ii) For all other disclosures, a covered entity must:
 - (A) Develop criteria designed to limit the protected health information disclosed to the information reasonably necessary to accomplish the purpose for which disclosure is sought; and
 - (B) Review requests for disclosure on an individual basis in accordance with such criteria.
- (iii) A covered entity may rely, if such reliance is reasonable under the circumstances, on a requested disclosure as the minimum necessary for the stated purpose when:
 - (A) Making disclosures to public officials that are permitted under § 164.512, if the public official represents that the information requested is the minimum necessary for the stated purpose(s);
 - (B) The information is requested by another covered entity;
 - (C) The information is requested by a professional who is a member of its workforce or is a business associate of the covered entity for the purpose of providing professional services to the covered entity, if the professional represents that the information requested is the minimum necessary for the stated purpose(s); or
 - (D) Documentation or representations that comply with the applicable requirements of § 164.512(i) have been provided by a person requesting the information for research purposes.

(4) *Implementation specifications: Minimum necessary requests for protected health information.*

- (i) A covered entity must limit any request for protected health information to that which is reasonably necessary to accomplish the purpose for which the request is made, when requesting such information from other covered entities.
- (ii) For a request that is made on a routine and recurring basis, a covered entity must implement policies and procedures (which may be standard protocols) that limit the protected health information requested to the amount reasonably necessary to accomplish the purpose for which the request is made.

(iii) For all other requests, a covered entity must:

(A) Develop criteria designed to limit the request for protected health information to the information reasonably necessary to accomplish the purpose for which the request is made; and

(B) Review requests for disclosure on an individual basis in accordance with such criteria.

(5) **Implementation specification: Other content requirement.** For all uses, disclosures, or requests to which the requirements in paragraph (d) of this section apply, a covered entity may not use, disclose or request an entire medical record, except when the entire medical record is specifically justified as the amount that is reasonably necessary to accomplish the purpose of the use, disclosure, or request.

(e)

(1) **Standard: Limited data set.** A covered entity may use or disclose a limited data set that meets the requirements of paragraphs (e)(2) and (e)(3) of this section, if the covered entity enters into a data use agreement with the limited data set recipient, in accordance with paragraph (e)(4) of this section.

(2) **Implementation specification: Limited data set:** A limited data set is protected health information that excludes the following direct identifiers of the individual or of relatives, employers, or household members of the individual:

(i) Names;

(ii) Postal address information, other than town or city, State, and zip code;

(iii) Telephone numbers;

(iv) Fax numbers;

(v) Electronic mail addresses;

(vi) Social security numbers;

(vii) Medical record numbers;

(viii) Health plan beneficiary numbers;

(ix) Account numbers;

(x) Certificate/license numbers;

(xi) Vehicle identifiers and serial numbers, including license plate numbers;

(xii) Device identifiers and serial numbers;

(xiii) Web Universal Resource Locators (URLs);

(xiv) Internet Protocol (IP) address numbers;

(xv) Biometric identifiers, including finger and voice prints; and

(xvi) Full face photographic images and any comparable images.

(3) **Implementation specification: Permitted purposes for uses and disclosures.**

- (i) A covered entity may use or disclose a limited data set under paragraph (e)(1) of this section only for the purposes of research, public health, or health care operations.
- (ii) A covered entity may use protected health information to create a limited data set that meets the requirements of paragraph (e)(2) of this section, or disclose protected health information only to a business associate for such purpose, whether or not the limited data set is to be used by the covered entity.

(4) **Implementation specifications: Data use agreement —**

- (i) **Agreement required.** A covered entity may use or disclose a limited data set under paragraph (e)(1) of this section only if the covered entity obtains satisfactory assurance, in the form of a data use agreement that meets the requirements of this section, that the limited data set recipient will only use or disclose the protected health information for limited purposes.
- (ii) **Contents.** A data use agreement between the covered entity and the limited data set recipient must:
 - (A) Establish the permitted uses and disclosures of such information by the limited data set recipient, consistent with paragraph (e)(3) of this section. The data use agreement may not authorize the limited data set recipient to use or further disclose the information in a manner that would violate the requirements of this subpart, if done by the covered entity;
 - (B) Establish who is permitted to use or receive the limited data set; and
 - (C) Provide that the limited data set recipient will:
 - (1) Not use or further disclose the information other than as permitted by the data use agreement or as otherwise required by law;
 - (2) Use appropriate safeguards to prevent use or disclosure of the information other than as provided for by the data use agreement;
 - (3) Report to the covered entity any use or disclosure of the information not provided for by its data use agreement of which it becomes aware;
 - (4) Ensure that any agents to whom it provides the limited data set agree to the same restrictions and conditions that apply to the limited data set recipient with respect to such information; and
 - (5) Not identify the information or contact the individuals.
- (iii) **Compliance.**
 - (A) A covered entity is not in compliance with the standards in paragraph (e) of this section if the covered entity knew of a pattern of activity or practice of the limited data set recipient that constituted a material breach or violation of the data use agreement, unless the covered entity took reasonable steps to cure the breach or end the violation, as applicable, and, if such steps were unsuccessful:
 - (1) Discontinued disclosure of protected health information to the recipient; and
 - (2) Reported the problem to the Secretary.

- (B) A covered entity that is a limited data set recipient and violates a data use agreement will be in noncompliance with the standards, implementation specifications, and requirements of paragraph (e) of this section.

(f) **Fundraising communications** —

- (1) **Standard: Uses and disclosures for fundraising.** Subject to the conditions of paragraph (f)(2) of this section, a covered entity may use, or disclose to a business associate or to an institutionally related foundation, the following protected health information for the purpose of raising funds for its own benefit, without an authorization meeting the requirements of § 164.508:

- (i) Demographic information relating to an individual, including name, address, other contact information, age, gender, and date of birth;
- (ii) Dates of health care provided to an individual;
- (iii) Department of service information;
- (iv) Treating physician;
- (v) Outcome information; and
- (vi) Health insurance status.

- (2) **Implementation specifications: Fundraising requirements.**

- (i) A covered entity may not use or disclose protected health information for fundraising purposes as otherwise permitted by paragraph (f)(1) of this section unless a statement required by § 164.520(b)(1)(iii)(A) is included in the covered entity's notice of privacy practices.
- (ii) With each fundraising communication made to an individual under this paragraph, a covered entity must provide the individual with a clear and conspicuous opportunity to elect not to receive any further fundraising communications. The method for an individual to elect not to receive further fundraising communications may not cause the individual to incur an undue burden or more than a nominal cost.
- (iii) A covered entity may not condition treatment or payment on the individual's choice with respect to the receipt of fundraising communications.
- (iv) A covered entity may not make fundraising communications to an individual under this paragraph where the individual has elected not to receive such communications under paragraph (f)(2)(ii) of this section.
- (v) A covered entity may provide an individual who has elected not to receive further fundraising communications with a method to opt back in to receive such communications.

- (g) **Standard: Uses and disclosures for underwriting and related purposes.** If a health plan receives protected health information for the purpose of underwriting, premium rating, or other activities relating to the creation, renewal, or replacement of a contract of health insurance or health benefits, and if such health insurance or health benefits are not placed with the health plan, such health plan may only use or disclose such protected health information for such purpose or as may be required by law, subject to the prohibition at § 164.502(a)(5)(i) with respect to genetic information included in the protected health information.

(h)

- (1) **Standard: Verification requirements.** Prior to any disclosure permitted by this subpart, a covered entity must:
 - (i) Except with respect to disclosures under § 164.510, verify the identity of a person requesting protected health information and the authority of any such person to have access to protected health information under this subpart, if the identity or any such authority of such person is not known to the covered entity; and
 - (ii) Obtain any documentation, statements, or representations, whether oral or written, from the person requesting the protected health information when such documentation, statement, or representation is a condition of the disclosure under this subpart.
- (2) **Implementation specifications: Verification –**
 - (i) **Conditions on disclosures.** If a disclosure is conditioned by this subpart on particular documentation, statements, or representations from the person requesting the protected health information, a covered entity may rely, if such reliance is reasonable under the circumstances, on documentation, statements, or representations that, on their face, meet the applicable requirements.
 - (A) The conditions in § 164.512(f)(1)(ii)(C) may be satisfied by the administrative subpoena or similar process or by a separate written statement that, on its face, demonstrates that the applicable requirements have been met.
 - (B) The documentation required by § 164.512(i)(2) may be satisfied by one or more written statements, provided that each is appropriately dated and signed in accordance with § 164.512(i)(2)(i) and (v).
 - (ii) **Identity of public officials.** A covered entity may rely, if such reliance is reasonable under the circumstances, on any of the following to verify identity when the disclosure of protected health information is to a public official or a person acting on behalf of the public official:
 - (A) If the request is made in person, presentation of an agency identification badge, other official credentials, or other proof of government status;
 - (B) If the request is in writing, the request is on the appropriate government letterhead; or
 - (C) If the disclosure is to a person acting on behalf of a public official, a written statement on appropriate government letterhead that the person is acting under the government's authority or other evidence or documentation of agency, such as a contract for services, memorandum of understanding, or purchase order, that establishes that the person is acting on behalf of the public official.
 - (iii) **Authority of public officials.** A covered entity may rely, if such reliance is reasonable under the circumstances, on any of the following to verify authority when the disclosure of protected health information is to a public official or a person acting on behalf of the public official:
 - (A) A written statement of the legal authority under which the information is requested, or, if a written statement would be impracticable, an oral statement of such legal authority;
 - (B) If a request is made pursuant to legal process, warrant, subpoena, order, or other legal process issued by a grand jury or a judicial or administrative tribunal is presumed to constitute legal authority.

- (iv) **Exercise of professional judgment.** The verification requirements of this paragraph are met if the covered entity relies on the exercise of professional judgment in making a use or disclosure in accordance with § 164.510 or acts on a good faith belief in making a disclosure in accordance with § 164.512(j).

[65 FR 82802, Dec. 28, 2000, as amended at 67 FR 53270, Aug. 14, 2002; 78 FR 5700, Jan. 25, 2013; 78 FR 34266, June 7, 2013]

§ 164.520 Notice of privacy practices for protected health information.

(a) **Standard: Notice of privacy practices —**

- (1) **Right to notice.** Except as provided by paragraph (a)(3) or (4) of this section, an individual has a right to adequate notice of the uses and disclosures of protected health information that may be made by the covered entity, and of the individual's rights and the covered entity's legal duties with respect to protected health information.
- (2) **Notice requirements for covered entities creating or maintaining records subject to 42 U.S.C. 290dd-2.** As provided in 42 CFR 2.22, an individual who is the subject of records protected under 42 CFR part 2 has a right to adequate notice of the uses and disclosures of such records, and of the individual's rights and the covered entity's legal duties with respect to such records.
- (3) **Exception for group health plans.**
 - (i) An individual enrolled in a group health plan has a right to notice:
 - (A) From the group health plan, if, and to the extent that, such an individual does not receive health benefits under the group health plan through an insurance contract with a health insurance issuer or HMO; or
 - (B) From the health insurance issuer or HMO with respect to the group health plan through which such individuals receive their health benefits under the group health plan.
 - (ii) A group health plan that provides health benefits solely through an insurance contract with a health insurance issuer or HMO, and that creates or receives protected health information in addition to summary health information as defined in § 164.504(a) or information on whether the individual is participating in the group health plan, or is enrolled in or has disenrolled from a health insurance issuer or HMO offered by the plan, must:
 - (A) Maintain a notice under this section; and
 - (B) Provide such notice upon request to any person. The provisions of paragraph (c)(1) of this section do not apply to such group health plan.
 - (iii) A group health plan that provides health benefits solely through an insurance contract with a health insurance issuer or HMO, and does not create or receive protected health information other than summary health information as defined in § 164.504(a) or information on whether an individual is participating in the group health plan, or is enrolled in or has disenrolled from a health insurance issuer or HMO offered by the plan, is not required to maintain or provide a notice under this section.
- (4) **Exception for inmates.** An inmate does not have a right to notice under this section, and the requirements of this section do not apply to a correctional institution that is a covered entity.

(b) **Implementation specifications: Content of notice —**

- (1) **Required elements.** The covered entity, including any covered entity receiving or maintaining records subject to 42 U.S.C. 290dd-2, must provide a notice that is written in plain language and that contains the elements required by this paragraph.

- (i) **Header.** The notice must contain the following statement as a header or otherwise prominently displayed:

"THIS NOTICE DESCRIBES HOW MEDICAL INFORMATION ABOUT YOU MAY BE USED AND DISCLOSED AND HOW YOU CAN GET ACCESS TO THIS INFORMATION. PLEASE REVIEW IT CAREFULLY."

- (ii) **Uses and disclosures.** The notice must contain:

- (A) A description, including at least one example, of the types of uses and disclosures that the covered entity is permitted by this subpart to make for each of the following purposes: treatment, payment, and health care operations.
- (B) A description of each of the other purposes for which the covered entity is permitted or required by this subpart to use or disclose protected health information without the individual's written authorization.
- (C) If a use or disclosure for any purpose described in paragraphs (b)(1)(ii)(A) or (B) of this section is prohibited or materially limited by other applicable law, such as 42 CFR part 2, the description of such use or disclosure must reflect the more stringent law as defined in § 160.202 of this subchapter.
- (D) For each purpose described in paragraph (b)(1)(ii)(A) or (B) of this section, the description must include sufficient detail to place the individual on notice of the uses and disclosures that are permitted or required by this subpart and other applicable law, such as 42 CFR part 2.
- (E) A description of the types of uses and disclosures that require an authorization under § 164.508(a)(2)-(a)(4), a statement that other uses and disclosures not described in the notice will be made only with the individual's written authorization, and a statement that the individual may revoke an authorization as provided by § 164.508(b)(5).
- (F) A description, including at least one example, of the types of uses and disclosures prohibited under § 164.502(a)(5)(iii) in sufficient detail for an individual to understand the prohibition.
- (G) A description, including at least one example, of the types of uses and disclosures for which an attestation is required under § 164.509.
- (H) A statement adequate to put the individual on notice of the potential for information disclosed pursuant to this subpart to be subject to redisclosure by the recipient and no longer protected by this subpart

- (iii) **Separate statements for certain uses or disclosures.** If the covered entity intends to engage in any of the following activities, the description required by paragraph (b)(1)(ii)(A) or (B) of this section must include a separate statement informing the individual of such activities, as applicable:

- (A) In accordance with § 164.514(f)(1), the covered entity may contact the individual to raise funds for the covered entity and the individual has a right to opt out of receiving such communications;
 - (B) In accordance with § 164.504(f), the group health plan, or a health insurance issuer or HMO with respect to a group health plan, may disclose protected health information to the sponsor of the plan;
 - (C) If a covered entity that is a health plan, excluding an issuer of a long-term care policy falling within paragraph (1)(viii) of the definition of *health plan*, intends to use or disclose protected health information for underwriting purposes, a statement that the covered entity is prohibited from using or disclosing protected health information that is genetic information of an individual for such purposes;
 - (D) Substance use disorder treatment records received from programs subject to 42 CFR part 2, or testimony relaying the content of such records, shall not be used or disclosed in civil, criminal, administrative, or legislative proceedings against the individual unless based on written consent, or a court order after notice and an opportunity to be heard is provided to the individual or the holder of the record, as provided in 42 CFR part 2. A court order authorizing use or disclosure must be accompanied by a subpoena or other legal requirement compelling disclosure before the requested record is used or disclosed; or
 - (E) If a covered entity that creates or maintains records subject to 42 CFR part 2 intends to use or disclose such records for fundraising for the benefit of the covered entity, the individual must first be provided with a clear and conspicuous opportunity to elect not to receive any fundraising communications.
- (iv) **Individual rights.** The notice must contain a statement of the individual's rights with respect to protected health information and a brief description of how the individual may exercise these rights, as follows:
- (A) The right to request restrictions on certain uses and disclosures of protected health information as provided by § 164.522(a), including a statement that the covered entity is not required to agree to a requested restriction, except in case of a disclosure restricted under § 164.522(a)(1)(vi);
 - (B) The right to receive confidential communications of protected health information as provided by § 164.522(b), as applicable;
 - (C) The right to inspect and copy protected health information as provided by § 164.524;
 - (D) The right to amend protected health information as provided by § 164.526;
 - (E) The right to receive an accounting of disclosures of protected health information as provided by § 164.528; and
 - (F) The right of an individual, including an individual who has agreed to receive the notice electronically in accordance with paragraph (c)(3) of this section, to obtain a paper copy of the notice from the covered entity upon request.
- (v) **Covered entity's duties.** The notice must contain:

- (A) A statement that the covered entity is required by law to maintain the privacy of protected health information, to provide individuals with notice of its legal duties and privacy practices, and to notify affected individuals following a breach of unsecured protected health information;
 - (B) A statement that the covered entity is required to abide by the terms of the notice currently in effect; and
 - (C) For the covered entity to apply a change in a privacy practice that is described in the notice to protected health information that the covered entity created or received prior to issuing a revised notice, in accordance with § 164.530(i)(2)(ii), a statement that it reserves the right to change the terms of its notice and to make the new notice provisions effective for all protected health information that it maintains. The statement must also describe how it will provide individuals with a revised notice.
- (vi) **Complaints.** The notice must contain a statement that individuals may complain to the covered entity and to the Secretary if they believe their privacy rights have been violated, a brief description of how the individual may file a complaint with the covered entity, and a statement that the individual will not be retaliated against for filing a complaint.
 - (vii) **Contact.** The notice must contain the name, or title, and telephone number of a person or office to contact for further information as required by § 164.530(a)(1)(ii).
 - (viii) **Effective date.** The notice must contain the date on which the notice is first in effect, which may not be earlier than the date on which the notice is printed or otherwise published.

(2) **Optional elements.**

- (i) In addition to the information required by paragraph (b)(1) of this section, if a covered entity elects to limit the uses or disclosures that it is permitted to make under this subpart, the covered entity may describe its more limited uses or disclosures in its notice, provided that the covered entity may not include in its notice a limitation affecting its right to make a use or disclosure that is required by law or permitted by § 164.512(j)(1)(i).
- (ii) For the covered entity to apply a change in its more limited uses and disclosures to protected health information created or received prior to issuing a revised notice, in accordance with § 164.530(i)(2)(ii), the notice must include the statements required by paragraph (b)(1)(v)(C) of this section.

(3) **Revisions to the notice.** The covered entity must promptly revise and distribute its notice whenever there is a material change to the uses or disclosures, the individual's rights, the covered entity's legal duties, or other privacy practices stated in the notice. Except when required by law, a material change to any term of the notice may not be implemented prior to the effective date of the notice in which such material change is reflected.

(c) **Implementation specifications: Provision of notice.** A covered entity must make the notice required by this section available on request to any person and to individuals as specified in paragraphs (c)(1) through (c)(3) of this section, as applicable.

(1) **Specific requirements for health plans.**

- (i) A health plan must provide the notice:

- (A) No later than the compliance date for the health plan, to individuals then covered by the plan;
 - (B) Thereafter, at the time of enrollment, to individuals who are new enrollees.
- (ii) No less frequently than once every three years, the health plan must notify individuals then covered by the plan of the availability of the notice and how to obtain the notice.
- (iii) The health plan satisfies the requirements of paragraph (c)(1) of this section if notice is provided to the named insured of a policy under which coverage is provided to the named insured and one or more dependents.
- (iv) If a health plan has more than one notice, it satisfies the requirements of paragraph (c)(1) of this section by providing the notice that is relevant to the individual or other person requesting the notice.
- (v) If there is a material change to the notice:
 - (A) A health plan that posts its notice on its web site in accordance with paragraph (c)(3)(i) of this section must prominently post the change or its revised notice on its web site by the effective date of the material change to the notice, and provide the revised notice, or information about the material change and how to obtain the revised notice, in its next annual mailing to individuals then covered by the plan.
 - (B) A health plan that does not post its notice on a web site pursuant to paragraph (c)(3)(i) of this section must provide the revised notice, or information about the material change and how to obtain the revised notice, to individuals then covered by the plan within 60 days of the material revision to the notice.
- (2) ***Specific requirements for certain covered health care providers.*** A covered health care provider that has a direct treatment relationship with an individual must:
 - (i) Provide the notice:
 - (A) No later than the date of the first service delivery, including service delivered electronically, to such individual after the compliance date for the covered health care provider; or
 - (B) In an emergency treatment situation, as soon as reasonably practicable after the emergency treatment situation.
 - (ii) Except in an emergency treatment situation, make a good faith effort to obtain a written acknowledgment of receipt of the notice provided in accordance with paragraph (c)(2)(i) of this section, and if not obtained, document its good faith efforts to obtain such acknowledgment and the reason why the acknowledgment was not obtained;
 - (iii) If the covered health care provider maintains a physical service delivery site:
 - (A) Have the notice available at the service delivery site for individuals to request to take with them; and
 - (B) Post the notice in a clear and prominent location where it is reasonable to expect individuals seeking service from the covered health care provider to be able to read the notice; and

- (iv) Whenever the notice is revised, make the notice available upon request on or after the effective date of the revision and promptly comply with the requirements of paragraph (c)(2)(iii) of this section, if applicable.

(3) ***Specific requirements for electronic notice.***

- (i) A covered entity that maintains a web site that provides information about the covered entity's customer services or benefits must prominently post its notice on the web site and make the notice available electronically through the web site.
- (ii) A covered entity may provide the notice required by this section to an individual by e-mail, if the individual agrees to electronic notice and such agreement has not been withdrawn. If the covered entity knows that the e-mail transmission has failed, a paper copy of the notice must be provided to the individual. Provision of electronic notice by the covered entity will satisfy the provision requirements of paragraph (c) of this section when timely made in accordance with paragraph (c)(1) or (2) of this section.
- (iii) For purposes of paragraph (c)(2)(i) of this section, if the first service delivery to an individual is delivered electronically, the covered health care provider must provide electronic notice automatically and contemporaneously in response to the individual's first request for service. The requirements in paragraph (c)(2)(ii) of this section apply to electronic notice.
- (iv) The individual who is the recipient of electronic notice retains the right to obtain a paper copy of the notice from a covered entity upon request.

(d) ***Implementation specifications: Joint notice by separate covered entities.*** Covered entities that participate in organized health care arrangements may comply with this section by a joint notice, provided that:

- (1) The covered entities participating in the organized health care arrangement agree to abide by the terms of the notice with respect to protected health information created or received by the covered entity as part of its participation in the organized health care arrangement;
- (2) The joint notice meets the implementation specifications in paragraph (b) of this section, except that the statements required by this section may be altered to reflect the fact that the notice covers more than one covered entity; and
 - (i) Describes with reasonable specificity the covered entities, or class of entities, to which the joint notice applies;
 - (ii) Describes with reasonable specificity the service delivery sites, or classes of service delivery sites, to which the joint notice applies; and
 - (iii) If applicable, states that the covered entities participating in the organized health care arrangement will share protected health information with each other, as necessary to carry out treatment, payment, or health care operations relating to the organized health care arrangement.
- (3) The covered entities included in the joint notice must provide the notice to individuals in accordance with the applicable implementation specifications of paragraph (c) of this section. Provision of the joint notice to an individual by any one of the covered entities included in the joint notice will satisfy the provision requirement of paragraph (c) of this section with respect to all others covered by the joint notice.

- (4) The permission in paragraph (d) of this section for covered entities that participate in an organized health care arrangement to issue a joint notice may not be construed to remove any obligations or duties of entities creating or maintaining records subject to 42 U.S.C. 290dd-2, or to remove any rights of patients who are the subjects of such records.
- (e) **Implementation specifications: Documentation.** A covered entity must document compliance with the notice requirements, as required by § 164.530(j), by retaining copies of the notices issued by the covered entity and, if applicable, any written acknowledgments of receipt of the notice or documentation of good faith efforts to obtain such written acknowledgment, in accordance with paragraph (c)(2)(ii) of this section.

[65 FR 82802, Dec. 28, 2000, as amended at 67 FR 53271, Aug. 14, 2002; 78 FR 5701, Jan. 25, 2013; 89 FR 33064, Apr. 26, 2024]

§ 164.522 Rights to request privacy protection for protected health information.

(a)

(1) **Standard: Right of an individual to request restriction of uses and disclosures.**

- (i) A covered entity must permit an individual to request that the covered entity restrict:
 - (A) Uses or disclosures of protected health information about the individual to carry out treatment, payment, or health care operations; and
 - (B) Disclosures permitted under § 164.510(b).
- (ii) Except as provided in paragraph (a)(1)(vi) of this section, a covered entity is not required to agree to a restriction.
- (iii) A covered entity that agrees to a restriction under paragraph (a)(1)(i) of this section may not use or disclose protected health information in violation of such restriction, except that, if the individual who requested the restriction is in need of emergency treatment and the restricted protected health information is needed to provide the emergency treatment, the covered entity may use the restricted protected health information, or may disclose such information to a health care provider, to provide such treatment to the individual.
- (iv) If restricted protected health information is disclosed to a health care provider for emergency treatment under paragraph (a)(1)(iii) of this section, the covered entity must request that such health care provider not further use or disclose the information.
- (v) A restriction agreed to by a covered entity under paragraph (a) of this section, is not effective under this subpart to prevent uses or disclosures permitted or required under § 164.502(a)(2)(ii), § 164.510(a) or § 164.512.
- (vi) A covered entity must agree to the request of an individual to restrict disclosure of protected health information about the individual to a health plan if:
 - (A) The disclosure is for the purpose of carrying out payment or health care operations and is not otherwise required by law; and
 - (B) The protected health information pertains solely to a health care item or service for which the individual, or person other than the health plan on behalf of the individual, has paid the covered entity in full.

(2) **Implementation specifications: Terminating a restriction.** A covered entity may terminate a restriction, if:

- (i) The individual agrees to or requests the termination in writing;
- (ii) The individual orally agrees to the termination and the oral agreement is documented; or
- (iii) The covered entity informs the individual that it is terminating its agreement to a restriction, except that such termination is:
 - (A) Not effective for protected health information restricted under paragraph (a)(1)(vi) of this section; and
 - (B) Only effective with respect to protected health information created or received after it has so informed the individual.

(3) **Implementation specification: Documentation.** A covered entity must document a restriction in accordance with § 160.530(j) of this subchapter.

(b)

(1) **Standard: Confidential communications requirements.**

- (i) A covered health care provider must permit individuals to request and must accommodate reasonable requests by individuals to receive communications of protected health information from the covered health care provider by alternative means or at alternative locations.
- (ii) A health plan must permit individuals to request and must accommodate reasonable requests by individuals to receive communications of protected health information from the health plan by alternative means or at alternative locations, if the individual clearly states that the disclosure of all or part of that information could endanger the individual.

(2) **Implementation specifications: Conditions on providing confidential communications.**

- (i) A covered entity may require the individual to make a request for a confidential communication described in paragraph (b)(1) of this section in writing.
- (ii) A covered entity may condition the provision of a reasonable accommodation on:
 - (A) When appropriate, information as to how payment, if any, will be handled; and
 - (B) Specification of an alternative address or other method of contact.
- (iii) A covered health care provider may not require an explanation from the individual as to the basis for the request as a condition of providing communications on a confidential basis.
- (iv) A health plan may require that a request contain a statement that disclosure of all or part of the information to which the request pertains could endanger the individual.

[65 FR 82802, Dec. 28, 2000, as amended at 67 FR 53271, Aug. 14, 2002; 78 FR 5701, Jan. 25, 2013]

§ 164.524 Access of individuals to protected health information.

(a) **Standard: Access to protected health information —**

- (1) **Right of access.** Except as otherwise provided in paragraph (a)(2) or (a)(3) of this section, an individual has a right of access to inspect and obtain a copy of protected health information about the individual in a designated record set, for as long as the protected health information is maintained in the designated record set, except for:
 - (i) Psychotherapy notes; and
 - (ii) Information compiled in reasonable anticipation of, or for use in, a civil, criminal, or administrative action or proceeding.
- (2) **Unreviewable grounds for denial.** A covered entity may deny an individual access without providing the individual an opportunity for review, in the following circumstances:
 - (i) The protected health information is excepted from the right of access by paragraph (a)(1) of this section.
 - (ii) A covered entity that is a correctional institution or a covered health care provider acting under the direction of the correctional institution may deny, in whole or in part, an inmate's request to obtain a copy of protected health information, if obtaining such copy would jeopardize the health, safety, security, custody, or rehabilitation of the individual or of other inmates, or the safety of any officer, employee, or other person at the correctional institution or responsible for the transporting of the inmate.
 - (iii) An individual's access to protected health information created or obtained by a covered health care provider in the course of research that includes treatment may be temporarily suspended for as long as the research is in progress, provided that the individual has agreed to the denial of access when consenting to participate in the research that includes treatment, and the covered health care provider has informed the individual that the right of access will be reinstated upon completion of the research.
 - (iv) An individual's access to protected health information that is contained in records that are subject to the Privacy Act, 5 U.S.C. 552a, may be denied, if the denial of access under the Privacy Act would meet the requirements of that law.
 - (v) An individual's access may be denied if the protected health information was obtained from someone other than a health care provider under a promise of confidentiality and the access requested would be reasonably likely to reveal the source of the information.
- (3) **Reviewable grounds for denial.** A covered entity may deny an individual access, provided that the individual is given a right to have such denials reviewed, as required by paragraph (a)(4) of this section, in the following circumstances:
 - (i) A licensed health care professional has determined, in the exercise of professional judgment, that the access requested is reasonably likely to endanger the life or physical safety of the individual or another person;
 - (ii) The protected health information makes reference to another person (unless such other person is a health care provider) and a licensed health care professional has determined, in the exercise of professional judgment, that the access requested is reasonably likely to cause substantial harm to such other person; or

(iii) The request for access is made by the individual's personal representative and a licensed health care professional has determined, in the exercise of professional judgment, that the provision of access to such personal representative is reasonably likely to cause substantial harm to the individual or another person.

(4) **Review of a denial of access.** If access is denied on a ground permitted under paragraph (a)(3) of this section, the individual has the right to have the denial reviewed by a licensed health care professional who is designated by the covered entity to act as a reviewing official and who did not participate in the original decision to deny. The covered entity must provide or deny access in accordance with the determination of the reviewing official under paragraph (d)(4) of this section.

(b) **Implementation specifications: Requests for access and timely action –**

(1) **Individual's request for access.** The covered entity must permit an individual to request access to inspect or to obtain a copy of the protected health information about the individual that is maintained in a designated record set. The covered entity may require individuals to make requests for access in writing, provided that it informs individuals of such a requirement.

(2) **Timely action by the covered entity.**

(i) Except as provided in paragraph (b)(2)(ii) of this section, the covered entity must act on a request for access no later than 30 days after receipt of the request as follows.

(A) If the covered entity grants the request, in whole or in part, it must inform the individual of the acceptance of the request and provide the access requested, in accordance with paragraph (c) of this section.

(B) If the covered entity denies the request, in whole or in part, it must provide the individual with a written denial, in accordance with paragraph (d) of this section.

(ii) If the covered entity is unable to take an action required by paragraph (b)(2)(i)(A) or (B) of this section within the time required by paragraph (b)(2)(i) of this section, as applicable, the covered entity may extend the time for such actions by no more than 30 days, provided that:

(A) The covered entity, within the time limit set by paragraph (b)(2)(i) of this section, as applicable, provides the individual with a written statement of the reasons for the delay and the date by which the covered entity will complete its action on the request; and

(B) The covered entity may have only one such extension of time for action on a request for access.

(c) **Implementation specifications: Provision of access.** If the covered entity provides an individual with access, in whole or in part, to protected health information, the covered entity must comply with the following requirements.

(1) **Providing the access requested.** The covered entity must provide the access requested by individuals, including inspection or obtaining a copy, or both, of the protected health information about them in designated record sets. If the same protected health information that is the subject of a request for access is maintained in more than one designated record set or at more than one location, the covered entity need only produce the protected health information once in response to a request for access.

(2) **Form of access requested.**

- (i) The covered entity must provide the individual with access to the protected health information in the form and format requested by the individual, if it is readily producible in such form and format; or, if not, in a readable hard copy form or such other form and format as agreed to by the covered entity and the individual.
 - (ii) Notwithstanding paragraph (c)(2)(i) of this section, if the protected health information that is the subject of a request for access is maintained in one or more designated record sets electronically and if the individual requests an electronic copy of such information, the covered entity must provide the individual with access to the protected health information in the electronic form and format requested by the individual, if it is readily producible in such form and format; or, if not, in a readable electronic form and format as agreed to by the covered entity and the individual.
 - (iii) The covered entity may provide the individual with a summary of the protected health information requested, in lieu of providing access to the protected health information or may provide an explanation of the protected health information to which access has been provided, if:
 - (A) The individual agrees in advance to such a summary or explanation; and
 - (B) The individual agrees in advance to the fees imposed, if any, by the covered entity for such summary or explanation.
- (3) ***Time and manner of access.***
- (i) The covered entity must provide the access as requested by the individual in a timely manner as required by paragraph (b)(2) of this section, including arranging with the individual for a convenient time and place to inspect or obtain a copy of the protected health information, or mailing the copy of the protected health information at the individual's request. The covered entity may discuss the scope, format, and other aspects of the request for access with the individual as necessary to facilitate the timely provision of access.
 - (ii) If an individual's request for access directs the covered entity to transmit the copy of protected health information directly to another person designated by the individual, the covered entity must provide the copy to the person designated by the individual. The individual's request must be in writing, signed by the individual, and clearly identify the designated person and where to send the copy of protected health information.
- (4) ***Fees.*** If the individual requests a copy of the protected health information or agrees to a summary or explanation of such information, the covered entity may impose a reasonable, cost-based fee, provided that the fee includes only the cost of:
- (i) Labor for copying the protected health information requested by the individual, whether in paper or electronic form;
 - (ii) Supplies for creating the paper copy or electronic media if the individual requests that the electronic copy be provided on portable media;
 - (iii) Postage, when the individual has requested the copy, or the summary or explanation, be mailed; and
 - (iv) Preparing an explanation or summary of the protected health information, if agreed to by the individual as required by paragraph (c)(2)(iii) of this section.

- (d) **Implementation specifications: Denial of access.** If the covered entity denies access, in whole or in part, to protected health information, the covered entity must comply with the following requirements.
- (1) **Making other information accessible.** The covered entity must, to the extent possible, give the individual access to any other protected health information requested, after excluding the protected health information as to which the covered entity has a ground to deny access.
 - (2) **Denial.** The covered entity must provide a timely, written denial to the individual, in accordance with paragraph (b)(2) of this section. The denial must be in plain language and contain:
 - (i) The basis for the denial;
 - (ii) If applicable, a statement of the individual's review rights under paragraph (a)(4) of this section, including a description of how the individual may exercise such review rights; and
 - (iii) A description of how the individual may complain to the covered entity pursuant to the complaint procedures in § 164.530(d) or to the Secretary pursuant to the procedures in § 160.306. The description must include the name, or title, and telephone number of the contact person or office designated in § 164.530(a)(1)(ii).
 - (3) **Other responsibility.** If the covered entity does not maintain the protected health information that is the subject of the individual's request for access, and the covered entity knows where the requested information is maintained, the covered entity must inform the individual where to direct the request for access.
 - (4) **Review of denial requested.** If the individual has requested a review of a denial under paragraph (a)(4) of this section, the covered entity must designate a licensed health care professional, who was not directly involved in the denial to review the decision to deny access. The covered entity must promptly refer a request for review to such designated reviewing official. The designated reviewing official must determine, within a reasonable period of time, whether or not to deny the access requested based on the standards in paragraph (a)(3) of this section. The covered entity must promptly provide written notice to the individual of the determination of the designated reviewing official and take other action as required by this section to carry out the designated reviewing official's determination.
- (e) **Implementation specification: Documentation.** A covered entity must document the following and retain the documentation as required by § 164.530(j):
- (1) The designated record sets that are subject to access by individuals; and
 - (2) The titles of the persons or offices responsible for receiving and processing requests for access by individuals.

[65 FR 82802, Dec. 28, 2000, as amended at 78 FR 5701, Jan. 25, 2013; 78 FR 34266, June 7, 2013; 79 FR 7316, Feb. 6, 2014]

§ 164.526 Amendment of protected health information.

- (a) **Standard: Right to amend.**
- (1) **Right to amend.** An individual has the right to have a covered entity amend protected health information or a record about the individual in a designated record set for as long as the protected health information is maintained in the designated record set.

(2) **Denial of amendment.** A covered entity may deny an individual's request for amendment, if it determines that the protected health information or record that is the subject of the request:

- (i) Was not created by the covered entity, unless the individual provides a reasonable basis to believe that the originator of protected health information is no longer available to act on the requested amendment;
- (ii) Is not part of the designated record set;
- (iii) Would not be available for inspection under § 164.524; or
- (iv) Is accurate and complete.

(b) **Implementation specifications: Requests for amendment and timely action –**

(1) **Individual's request for amendment.** The covered entity must permit an individual to request that the covered entity amend the protected health information maintained in the designated record set. The covered entity may require individuals to make requests for amendment in writing and to provide a reason to support a requested amendment, provided that it informs individuals in advance of such requirements.

(2) **Timely action by the covered entity.**

- (i) The covered entity must act on the individual's request for an amendment no later than 60 days after receipt of such a request, as follows.
 - (A) If the covered entity grants the requested amendment, in whole or in part, it must take the actions required by paragraphs (c)(1) and (2) of this section.
 - (B) If the covered entity denies the requested amendment, in whole or in part, it must provide the individual with a written denial, in accordance with paragraph (d)(1) of this section.
- (ii) If the covered entity is unable to act on the amendment within the time required by paragraph (b)(2)(i) of this section, the covered entity may extend the time for such action by no more than 30 days, provided that:
 - (A) The covered entity, within the time limit set by paragraph (b)(2)(i) of this section, provides the individual with a written statement of the reasons for the delay and the date by which the covered entity will complete its action on the request; and
 - (B) The covered entity may have only one such extension of time for action on a request for an amendment.

(c) **Implementation specifications: Accepting the amendment.** If the covered entity accepts the requested amendment, in whole or in part, the covered entity must comply with the following requirements.

- (1) **Making the amendment.** The covered entity must make the appropriate amendment to the protected health information or record that is the subject of the request for amendment by, at a minimum, identifying the records in the designated record set that are affected by the amendment and appending or otherwise providing a link to the location of the amendment.
- (2) **Informing the individual.** In accordance with paragraph (b) of this section, the covered entity must timely inform the individual that the amendment is accepted and obtain the individual's identification of and agreement to have the covered entity notify the relevant persons with which the amendment needs to be shared in accordance with paragraph (c)(3) of this section.

(3) **Informing others.** The covered entity must make reasonable efforts to inform and provide the amendment within a reasonable time to:

- (i) Persons identified by the individual as having received protected health information about the individual and needing the amendment; and
- (ii) Persons, including business associates, that the covered entity knows have the protected health information that is the subject of the amendment and that may have relied, or could foreseeably rely, on such information to the detriment of the individual.

(d) **Implementation specifications: Denying the amendment.** If the covered entity denies the requested amendment, in whole or in part, the covered entity must comply with the following requirements.

(1) **Denial.** The covered entity must provide the individual with a timely, written denial, in accordance with paragraph (b)(2) of this section. The denial must use plain language and contain:

- (i) The basis for the denial, in accordance with paragraph (a)(2) of this section;
- (ii) The individual's right to submit a written statement disagreeing with the denial and how the individual may file such a statement;
- (iii) A statement that, if the individual does not submit a statement of disagreement, the individual may request that the covered entity provide the individual's request for amendment and the denial with any future disclosures of the protected health information that is the subject of the amendment; and
- (iv) A description of how the individual may complain to the covered entity pursuant to the complaint procedures established in § 164.530(d) or to the Secretary pursuant to the procedures established in § 160.306. The description must include the name, or title, and telephone number of the contact person or office designated in § 164.530(a)(1)(ii).

(2) **Statement of disagreement.** The covered entity must permit the individual to submit to the covered entity a written statement disagreeing with the denial of all or part of a requested amendment and the basis of such disagreement. The covered entity may reasonably limit the length of a statement of disagreement.

(3) **Rebuttal statement.** The covered entity may prepare a written rebuttal to the individual's statement of disagreement. Whenever such a rebuttal is prepared, the covered entity must provide a copy to the individual who submitted the statement of disagreement.

(4) **Recordkeeping.** The covered entity must, as appropriate, identify the record or protected health information in the designated record set that is the subject of the disputed amendment and append or otherwise link the individual's request for an amendment, the covered entity's denial of the request, the individual's statement of disagreement, if any, and the covered entity's rebuttal, if any, to the designated record set.

(5) **Future disclosures.**

- (i) If a statement of disagreement has been submitted by the individual, the covered entity must include the material appended in accordance with paragraph (d)(4) of this section, or, at the election of the covered entity, an accurate summary of any such information, with any subsequent disclosure of the protected health information to which the disagreement relates.

- (ii) If the individual has not submitted a written statement of disagreement, the covered entity must include the individual's request for amendment and its denial, or an accurate summary of such information, with any subsequent disclosure of the protected health information only if the individual has requested such action in accordance with paragraph (d)(1)(iii) of this section.
- (iii) When a subsequent disclosure described in paragraph (d)(5)(i) or (ii) of this section is made using a standard transaction under part 162 of this subchapter that does not permit the additional material to be included with the disclosure, the covered entity may separately transmit the material required by paragraph (d)(5)(i) or (ii) of this section, as applicable, to the recipient of the standard transaction.
- (e) **Implementation specification: Actions on notices of amendment.** A covered entity that is informed by another covered entity of an amendment to an individual's protected health information, in accordance with paragraph (c)(3) of this section, must amend the protected health information in designated record sets as provided by paragraph (c)(1) of this section.
- (f) **Implementation specification: Documentation.** A covered entity must document the titles of the persons or offices responsible for receiving and processing requests for amendments by individuals and retain the documentation as required by § 164.530(j).

§ 164.528 Accounting of disclosures of protected health information.

- (a) **Standard: Right to an accounting of disclosures of protected health information.**
 - (1) An individual has a right to receive an accounting of disclosures of protected health information made by a covered entity in the six years prior to the date on which the accounting is requested, except for disclosures:
 - (i) To carry out treatment, payment and health care operations as provided in § 164.506;
 - (ii) To individuals of protected health information about them as provided in § 164.502;
 - (iii) Incident to a use or disclosure otherwise permitted or required by this subpart, as provided in § 164.502;
 - (iv) Pursuant to an authorization as provided in § 164.508;
 - (v) For the facility's directory or to persons involved in the individual's care or other notification purposes as provided in § 164.510;
 - (vi) For national security or intelligence purposes as provided in § 164.512(k)(2);
 - (vii) To correctional institutions or law enforcement officials as provided in § 164.512(k)(5);
 - (viii) As part of a limited data set in accordance with § 164.514(e); or
 - (ix) That occurred prior to the compliance date for the covered entity.
 - (2)
 - (i) The covered entity must temporarily suspend an individual's right to receive an accounting of disclosures to a health oversight agency or law enforcement official, as provided in § 164.512(d) or (f), respectively, for the time specified by such agency or official, if such agency or official provides the covered entity with a written statement that such an accounting to the individual would be reasonably likely to impede the agency's activities and specifying the time for which such a suspension is required.

(ii) If the agency or official statement in paragraph (a)(2)(i) of this section is made orally, the covered entity must:

- (A) Document the statement, including the identity of the agency or official making the statement;
- (B) Temporarily suspend the individual's right to an accounting of disclosures subject to the statement; and
- (C) Limit the temporary suspension to no longer than 30 days from the date of the oral statement, unless a written statement pursuant to paragraph (a)(2)(i) of this section is submitted during that time.

(3) An individual may request an accounting of disclosures for a period of time less than six years from the date of the request.

(b) **Implementation specifications: Content of the accounting.** The covered entity must provide the individual with a written accounting that meets the following requirements.

(1) Except as otherwise provided by paragraph (a) of this section, the accounting must include disclosures of protected health information that occurred during the six years (or such shorter time period at the request of the individual as provided in paragraph (a)(3) of this section) prior to the date of the request for an accounting, including disclosures to or by business associates of the covered entity.

(2) Except as otherwise provided by paragraphs (b)(3) or (b)(4) of this section, the accounting must include for each disclosure:

- (i) The date of the disclosure;
- (ii) The name of the entity or person who received the protected health information and, if known, the address of such entity or person;
- (iii) A brief description of the protected health information disclosed; and
- (iv) A brief statement of the purpose of the disclosure that reasonably informs the individual of the basis for the disclosure or, in lieu of such statement, a copy of a written request for a disclosure under § 164.502(a)(2)(ii) or § 164.512, if any.

(3) If, during the period covered by the accounting, the covered entity has made multiple disclosures of protected health information to the same person or entity for a single purpose under § 164.502(a)(2)(ii) or § 164.512, the accounting may, with respect to such multiple disclosures, provide:

- (i) The information required by paragraph (b)(2) of this section for the first disclosure during the accounting period;
- (ii) The frequency, periodicity, or number of the disclosures made during the accounting period; and
- (iii) The date of the last such disclosure during the accounting period.

(4)

- (i) If, during the period covered by the accounting, the covered entity has made disclosures of protected health information for a particular research purpose in accordance with § 164.512(i) for 50 or more individuals, the accounting may, with respect to such disclosures for which the protected health information about the individual may have been included, provide:
 - (A) The name of the protocol or other research activity;
 - (B) A description, in plain language, of the research protocol or other research activity, including the purpose of the research and the criteria for selecting particular records;
 - (C) A brief description of the type of protected health information that was disclosed;
 - (D) The date or period of time during which such disclosures occurred, or may have occurred, including the date of the last such disclosure during the accounting period;
 - (E) The name, address, and telephone number of the entity that sponsored the research and of the researcher to whom the information was disclosed; and
 - (F) A statement that the protected health information of the individual may or may not have been disclosed for a particular protocol or other research activity.
- (ii) If the covered entity provides an accounting for research disclosures, in accordance with paragraph (b)(4) of this section, and if it is reasonably likely that the protected health information of the individual was disclosed for such research protocol or activity, the covered entity shall, at the request of the individual, assist in contacting the entity that sponsored the research and the researcher.

(c) **Implementation specifications: Provision of the accounting.**

- (1) The covered entity must act on the individual's request for an accounting, no later than 60 days after receipt of such a request, as follows.
 - (i) The covered entity must provide the individual with the accounting requested; or
 - (ii) If the covered entity is unable to provide the accounting within the time required by paragraph (c)(1) of this section, the covered entity may extend the time to provide the accounting by no more than 30 days, provided that:
 - (A) The covered entity, within the time limit set by paragraph (c)(1) of this section, provides the individual with a written statement of the reasons for the delay and the date by which the covered entity will provide the accounting; and
 - (B) The covered entity may have only one such extension of time for action on a request for an accounting.
- (2) The covered entity must provide the first accounting to an individual in any 12 month period without charge. The covered entity may impose a reasonable, cost-based fee for each subsequent request for an accounting by the same individual within the 12 month period, provided that the covered entity informs the individual in advance of the fee and provides the individual with an opportunity to withdraw or modify the request for a subsequent accounting in order to avoid or reduce the fee.

(d) **Implementation specification: Documentation.** A covered entity must document the following and retain the documentation as required by § 164.530(j):

- (1) The information required to be included in an accounting under paragraph (b) of this section for disclosures of protected health information that are subject to an accounting under paragraph (a) of this section;
- (2) The written accounting that is provided to the individual under this section; and
- (3) The titles of the persons or offices responsible for receiving and processing requests for an accounting by individuals.

[65 FR 82802, Dec. 28, 2000, as amended at 67 FR 53271, Aug. 14, 2002]

§ 164.530 Administrative requirements.

(a)

(1) **Standard: Personnel designations.**

- (i) A covered entity must designate a privacy official who is responsible for the development and implementation of the policies and procedures of the entity.
- (ii) A covered entity must designate a contact person or office who is responsible for receiving complaints under this section and who is able to provide further information about matters covered by the notice required by § 164.520.

(2) **Implementation specification: Personnel designations.** A covered entity must document the personnel designations in paragraph (a)(1) of this section as required by paragraph (j) of this section.

(b)

(1) **Standard: Training.** A covered entity must train all members of its workforce on the policies and procedures with respect to protected health information required by this subpart and subpart D of this part, as necessary and appropriate for the members of the workforce to carry out their functions within the covered entity.

(2) **Implementation specifications: Training.**

- (i) A covered entity must provide training that meets the requirements of paragraph (b)(1) of this section, as follows:
 - (A) To each member of the covered entity's workforce by no later than the compliance date for the covered entity;
 - (B) Thereafter, to each new member of the workforce within a reasonable period of time after the person joins the covered entity's workforce; and
 - (C) To each member of the covered entity's workforce whose functions are affected by a material change in the policies or procedures required by this subpart or subpart D of this part, within a reasonable period of time after the material change becomes effective in accordance with paragraph (i) of this section.
- (ii) A covered entity must document that the training as described in paragraph (b)(2)(i) of this section has been provided, as required by paragraph (j) of this section.

(c)

(1) **Standard: Safeguards.** A covered entity must have in place appropriate administrative, technical, and physical safeguards to protect the privacy of protected health information.

(2)

(i) **Implementation specification: Safeguards.** A covered entity must reasonably safeguard protected health information from any intentional or unintentional use or disclosure that is in violation of the standards, implementation specifications or other requirements of this subpart.

(ii) A covered entity must reasonably safeguard protected health information to limit incidental uses or disclosures made pursuant to an otherwise permitted or required use or disclosure.

(d)

(1) **Standard: Complaints to the covered entity.** A covered entity must provide a process for individuals to make complaints concerning the covered entity's policies and procedures required by this subpart and subpart D of this part or its compliance with such policies and procedures or the requirements of this subpart or subpart D of this part.

(2) **Implementation specification: Documentation of complaints.** As required by paragraph (j) of this section, a covered entity must document all complaints received, and their disposition, if any.

(e)

(1) **Standard: Sanctions.** A covered entity must have and apply appropriate sanctions against members of its workforce who fail to comply with the privacy policies and procedures of the covered entity or the requirements of this subpart or subpart D of this part. This standard does not apply to a member of the covered entity's workforce with respect to actions that are covered by and that meet the conditions of § 164.502(j) or paragraph (g)(2) of this section.

(2) **Implementation specification: Documentation.** As required by paragraph (j) of this section, a covered entity must document the sanctions that are applied, if any.

(f) **Standard: Mitigation.** A covered entity must mitigate, to the extent practicable, any harmful effect that is known to the covered entity of a use or disclosure of protected health information in violation of its policies and procedures or the requirements of this subpart by the covered entity or its business associate.

(g) **Standard: Refraining from intimidating or retaliatory acts.** A covered entity—

(1) May not intimidate, threaten, coerce, discriminate against, or take other retaliatory action against any individual for the exercise by the individual of any right established, or for participation in any process provided for, by this subpart or subpart D of this part, including the filing of a complaint under this section; and

(2) Must refrain from intimidation and retaliation as provided in § 160.316 of this subchapter.

(h) **Standard: Waiver of rights.** A covered entity may not require individuals to waive their rights under § 160.306 of this subchapter, this subpart, or subpart D of this part, as a condition of the provision of treatment, payment, enrollment in a health plan, or eligibility for benefits.

(i)

- (1) **Standard: Policies and procedures.** A covered entity must implement policies and procedures with respect to protected health information that are designed to comply with the standards, implementation specifications, or other requirements of this subpart and subpart D of this part. The policies and procedures must be reasonably designed, taking into account the size and the type of activities that relate to protected health information undertaken by a covered entity, to ensure such compliance. This standard is not to be construed to permit or excuse an action that violates any other standard, implementation specification, or other requirement of this subpart.
- (2) **Standard: Changes to policies and procedures.**
 - (i) A covered entity must change its policies and procedures as necessary and appropriate to comply with changes in the law, including the standards, requirements, and implementation specifications of this subpart or subpart D of this part.
 - (ii) When a covered entity changes a privacy practice that is stated in the notice described in § 164.520, and makes corresponding changes to its policies and procedures, it may make the changes effective for protected health information that it created or received prior to the effective date of the notice revision, if the covered entity has, in accordance with § 164.520(b)(1)(v)(C), included in the notice a statement reserving its right to make such a change in its privacy practices; or
 - (iii) A covered entity may make any other changes to policies and procedures at any time, provided that the changes are documented and implemented in accordance with paragraph (i)(5) of this section.
- (3) **Implementation specification: Changes in law.** Whenever there is a change in law that necessitates a change to the covered entity's policies or procedures, the covered entity must promptly document and implement the revised policy or procedure. If the change in law materially affects the content of the notice required by § 164.520, the covered entity must promptly make the appropriate revisions to the notice in accordance with § 164.520(b)(3). Nothing in this paragraph may be used by a covered entity to excuse a failure to comply with the law.
- (4) **Implementation specifications: Changes to privacy practices stated in the notice.**
 - (i) To implement a change as provided by paragraph (i)(2)(ii) of this section, a covered entity must:
 - (A) Ensure that the policy or procedure, as revised to reflect a change in the covered entity's privacy practice as stated in its notice, complies with the standards, requirements, and implementation specifications of this subpart;
 - (B) Document the policy or procedure, as revised, as required by paragraph (j) of this section; and
 - (C) Revise the notice as required by § 164.520(b)(3) to state the changed practice and make the revised notice available as required by § 164.520(c). The covered entity may not implement a change to a policy or procedure prior to the effective date of the revised notice.

(ii) If a covered entity has not reserved its right under § 164.520(b)(1)(v)(C) to change a privacy practice that is stated in the notice, the covered entity is bound by the privacy practices as stated in the notice with respect to protected health information created or received while such notice is in effect. A covered entity may change a privacy practice that is stated in the notice, and the related policies and procedures, without having reserved the right to do so, provided that:

(A) Such change meets the implementation specifications in paragraphs (i)(4)(i)(A)-(C) of this section; and

(B) Such change is effective only with respect to protected health information created or received after the effective date of the notice.

(5) **Implementation specification: Changes to other policies or procedures.** A covered entity may change, at any time, a policy or procedure that does not materially affect the content of the notice required by § 164.520, provided that:

(i) The policy or procedure, as revised, complies with the standards, requirements, and implementation specifications of this subpart; and

(ii) Prior to the effective date of the change, the policy or procedure, as revised, is documented as required by paragraph (j) of this section.

(j)

(1) **Standard: Documentation.** A covered entity must:

(i) Maintain the policies and procedures provided for in paragraph (i) of this section in written or electronic form;

(ii) If a communication is required by this subpart to be in writing, maintain such writing, or an electronic copy, as documentation; and

(iii) If an action, activity, or designation is required by this subpart to be documented, maintain a written or electronic record of such action, activity, or designation.

(iv) Maintain documentation sufficient to meet its burden of proof under § 164.414(b).

(2) **Implementation specification: Retention period.** A covered entity must retain the documentation required by paragraph (j)(1) of this section for six years from the date of its creation or the date when it last was in effect, whichever is later.

(k) **Standard: Group health plans.**

(1) A group health plan is not subject to the standards or implementation specifications in paragraphs (a) through (f) and (i) of this section, to the extent that:

(i) The group health plan provides health benefits solely through an insurance contract with a health insurance issuer or an HMO; and

(ii) The group health plan does not create or receive protected health information, except for:

(A) Summary health information as defined in § 164.504(a); or

(B) Information on whether the individual is participating in the group health plan, or is enrolled in or has disenrolled from a health insurance issuer or HMO offered by the plan.

- (2) A group health plan described in paragraph (k)(1) of this section is subject to the standard and implementation specification in paragraph (j) of this section only with respect to plan documents amended in accordance with § 164.504(f).

[65 FR 82802, Dec. 28, 2000, as amended at 67 FR 53272, Aug. 14, 2002; 71 FR 8433, Feb. 16, 2006; 74 FR 42769, Aug. 24, 2009]

§ 164.532 Transition provisions.

- (a) **Standard: Effect of prior authorizations.** Notwithstanding §§ 164.508 and 164.512(i), a covered entity may use or disclose protected health information, consistent with paragraphs (b) and (c) of this section, pursuant to an authorization or other express legal permission obtained from an individual permitting the use or disclosure of protected health information, informed consent of the individual to participate in research, a waiver of informed consent by an IRB, or a waiver of authorization in accordance with § 164.512(i)(1)(i).
- (b) **Implementation specification: Effect of prior authorization for purposes other than research.** Notwithstanding any provisions in § 164.508, a covered entity may use or disclose protected health information that it created or received prior to the applicable compliance date of this subpart pursuant to an authorization or other express legal permission obtained from an individual prior to the applicable compliance date of this subpart, provided that the authorization or other express legal permission specifically permits such use or disclosure and there is no agreed-to restriction in accordance with § 164.522(a).
- (c) **Implementation specification: Effect of prior permission for research.** Notwithstanding any provisions in §§ 164.508 and 164.512(i), a covered entity may, to the extent allowed by one of the following permissions, use or disclose, for research, protected health information that it created or received either before or after the applicable compliance date of this subpart, provided that there is no agreed-to restriction in accordance with § 164.522(a), and the covered entity has obtained, prior to the applicable compliance date, either:
- (1) An authorization or other express legal permission from an individual to use or disclose protected health information for the research;
 - (2) The informed consent of the individual to participate in the research;
 - (3) A waiver, by an IRB, of informed consent for the research, in accordance with 7 CFR 1c.116(d), 10 CFR 745.116(d), 14 CFR 1230.116(d), 15 CFR 27.116(d), 16 CFR 1028.116(d), 21 CFR 50.24, 22 CFR 225.116(d), 24 CFR 60.116(d), 28 CFR 46.116(d), 32 CFR 219.116(d), 34 CFR 97.116(d), 38 CFR 16.116(d), 40 CFR 26.116(d), 45 CFR 46.116(d), 45 CFR 690.116(d), or 49 CFR 11.116(d), provided that a covered entity must obtain authorization in accordance with § 164.508 if, after the compliance date, informed consent is sought from an individual participating in the research; or
 - (4) A waiver of authorization in accordance with § 164.512(i)(1)(i).
- (d) **Standard: Effect of prior contracts or other arrangements with business associates.** Notwithstanding any other provisions of this part, a covered entity, or business associate with respect to a subcontractor, may disclose protected health information to a business associate and may allow a business associate to create, receive, maintain, or transmit protected health information on its behalf pursuant to a written contract or other written arrangement with such business associate that does not comply with §§ 164.308(b), 164.314(a), 164.502(e), and 164.504(e), only in accordance with paragraph (e) of this section.
- (e) **Implementation specification: Deemed compliance —**

- (1) **Qualification.** Notwithstanding other sections of this part, a covered entity, or business associate with respect to a subcontractor, is deemed to be in compliance with the documentation and contract requirements of §§ 164.308(b), 164.314(a), 164.502(e), and 164.504(e), with respect to a particular business associate relationship, for the time period set forth in paragraph (e)(2) of this section, if:
 - (i) Prior to January 25, 2013, such covered entity, or business associate with respect to a subcontractor, has entered into and is operating pursuant to a written contract or other written arrangement with the business associate that complies with the applicable provisions of § 164.314(a) or § 164.504(e) that were in effect on such date; and
 - (ii) The contract or other arrangement is not renewed or modified from March 26, 2013, until September 23, 2013.
- (2) **Limited deemed compliance period.** A prior contract or other arrangement that meets the qualification requirements in paragraph (e) of this section shall be deemed compliant until the earlier of:
 - (i) The date such contract or other arrangement is renewed or modified on or after September 23, 2013; or
 - (ii) September 22, 2014.
- (3) **Covered entity responsibilities.** Nothing in this section shall alter the requirements of a covered entity to comply with part 160, subpart C of this subchapter and §§ 164.524, 164.526, 164.528, and 164.530(f) with respect to protected health information held by a business associate.
- (f) **Effect of prior data use agreements.** If, prior to January 25, 2013, a covered entity has entered into and is operating pursuant to a data use agreement with a recipient of a limited data set that complies with § 164.514(e), notwithstanding § 164.502(a)(5)(ii), the covered entity may continue to disclose a limited data set pursuant to such agreement in exchange for remuneration from or on behalf of the recipient of the protected health information until the earlier of:
 - (1) The date such agreement is renewed or modified on or after September 23, 2013; or
 - (2) September 22, 2014.

[65 FR 82802, Dec. 28, 2000, as amended at 67 FR 53272, Aug. 14, 2002; 78 FR 5702, Jan. 25, 2013; 78 FR 34266, June 7, 2013]

§ 164.534 Compliance dates for initial implementation of the privacy standards.

- (a) **Health care providers.** A covered health care provider must comply with the applicable requirements of this subpart no later than April 14, 2003.
- (b) **Health plans.** A health plan must comply with the applicable requirements of this subpart no later than the following as applicable:
 - (1) **Health plans other than small health plans.** April 14, 2003.
 - (2) **Small health plans.** April 14, 2004.
- (c) **Health clearinghouses.** A health care clearinghouse must comply with the applicable requirements of this subpart no later than April 14, 2003.

[66 FR 12434, Feb. 26, 2001]

§ 164.535 Severability.

If any provision of the HIPAA Privacy Rule to Support Reproductive Health Care Privacy is held to be invalid or unenforceable facially, or as applied to any person, plaintiff, or circumstance, it shall be construed to give maximum effect to the provision permitted by law, unless such holding shall be one of utter invalidity or unenforceability, in which case the provision shall be severable from this part and shall not affect the remainder thereof or the application of the provision to other persons not similarly situated or to other dissimilar circumstances.

[89 FR 33066, Apr. 26, 2024]